

Introduction a la Sécurité

Solutions de Sécurité

Enseignant: Assane Gueye

July, 2024

Sources:

Vern Paxson: Berkeley, CS 161

David Wagner: Berkeley, CS 161

IAEA

We have seen so far...

- Principes de Sécurité
 - Confidentialité
 - Intégrité
 - Disponibilité
 - Non-repudiation
- Menace, Vulnérabilité, Exploit, Attaque
 - Réseaux/Protocoles
 - Programme
 - L'être humain dans la boucle

...and Now!

How do we Protect Systems?

Mesures de sécurité informatique

What for???

Mesures de sécurité informatique

- Les mesures de sécurité informatiques sont utilisées pour **éviter, détecter, retarder**, et **répondre** (*en préparant la reprise d'activité*) à des actes malveillants ainsi que pour atténuer les conséquences de tels actes.
- Les mesures de sécurité informatiques sont aussi utilisées pour **s'assurer que les actes non-malveillants ne dégradent pas la sécurité** et n'augmentent pas la vulnérabilité des systèmes informatiques aux actes malveillants.

Mesures de sécurité informatique

Types de mesures/contrôle

Administratives

- politique, procédures et pratiques conçues pour sauvegarder les systèmes informatiques par les comportements du personnel. Ces mesures sont de nature directive, spécifiant ce que les employés devraient ou ne devraient pas faire.

Physiques

- barrières physiques pour la protection des ordinateurs et des actifs de support contre les dommages physiques et un accès physique (barrière, systèmes de protection physique, serrures, portes, gardes, protection contre les incendies)

Techniques

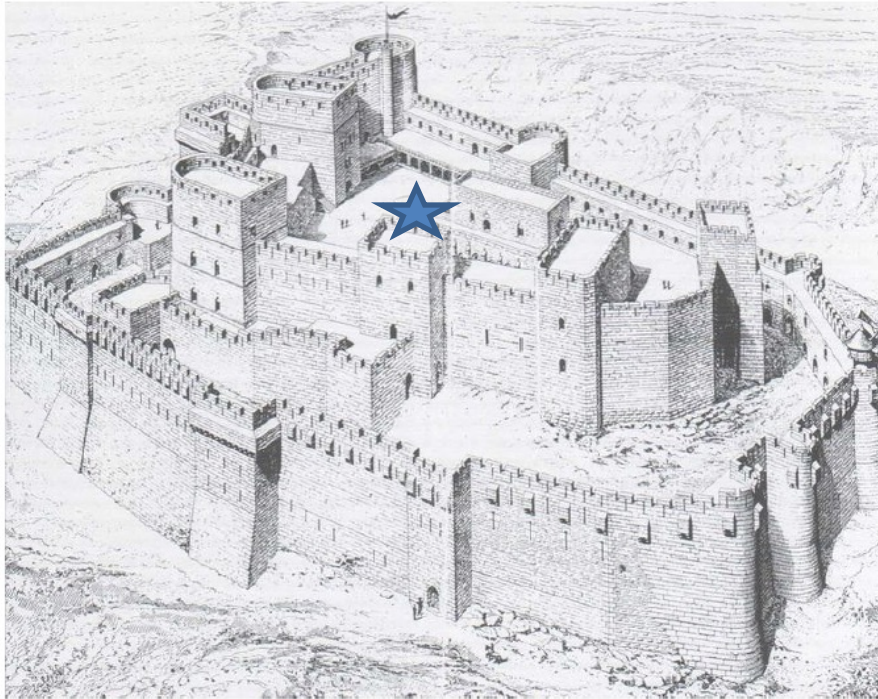
- Solutions informatiques de hardware/logiciels pour la protection, la détection, la mitigation et la réparation des dommages dus à l'intrusion ou à d'autres actes malveillants (par ex., des pare-feux, IDS, logiciels antivirus, contrôle d'accès)

Mesures de sécurité informatique

Physique

Protection physique

Principe de base: Défense en couches/lignes (profondeur)



Sur le **plan physique** (choix de la location de la salle des serveurs)...

...mais aussi sur le plan logique (sécurité des systèmes d'info...a venir)

Protection physique

Prévenir l'accès aux locaux



Portes sécurisées

Détection d'intrusion



Gardien



Détruire information sensible



Document papier!

Challenges avec document numérique!

- Copies dans plusieurs mediums (disque, emails, etc...)
- Est-ce que «DELETE» suffit?

Solutions: Réécrire sur le disque, brûler, faire passer dans puissante champ magnétique!

Sécurité du poste de travail

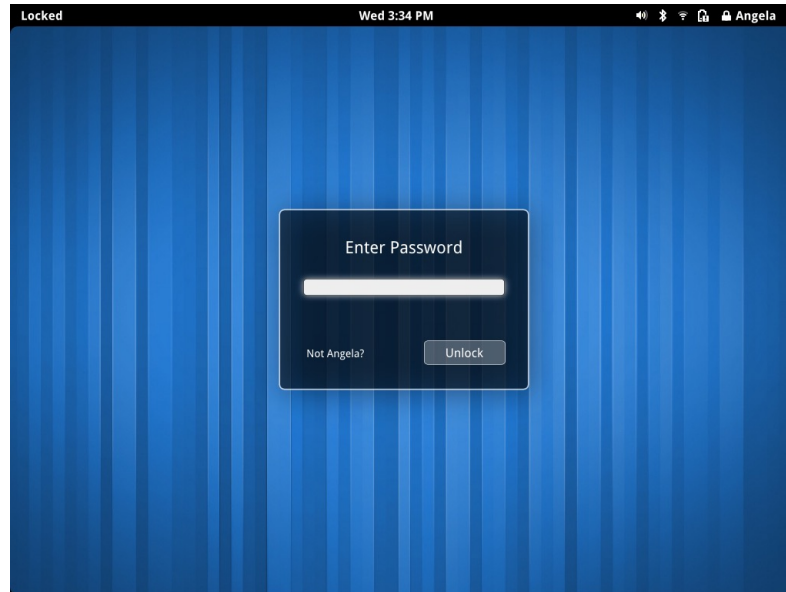
Anti-vol



Shoulder Surfing!



Solutions: bonne position + miroir!



- Verrouiller écran quand vous sortez (Shortcut: WIN+L)
- Automatique verrouillage après 5 minute d'inactivité
- Eteindre machine en fin de journée

Sécurité des appareils portables

Il faut les porter! Il faut les verrouiller! Il faut un backup!

Ton smartphone est un ordinateur:

- **Mettre a jour a façon régulière**
- **Enlever Apps si la source n'est pas sur**
- **Enlever Apps sans utilité...si tu n'as pas l'utiliser depuis 1 an...peut être tu n'en as pas besoin!**
- **Utiliser mode «Enfant », «visiteur »**
- **« Toujours » activer « location »... vous revelez qd même votre position a Google!**
- **Verrouiller le SIM**
- **Ne pas stocker des informations sensibles sur le téléphone!**

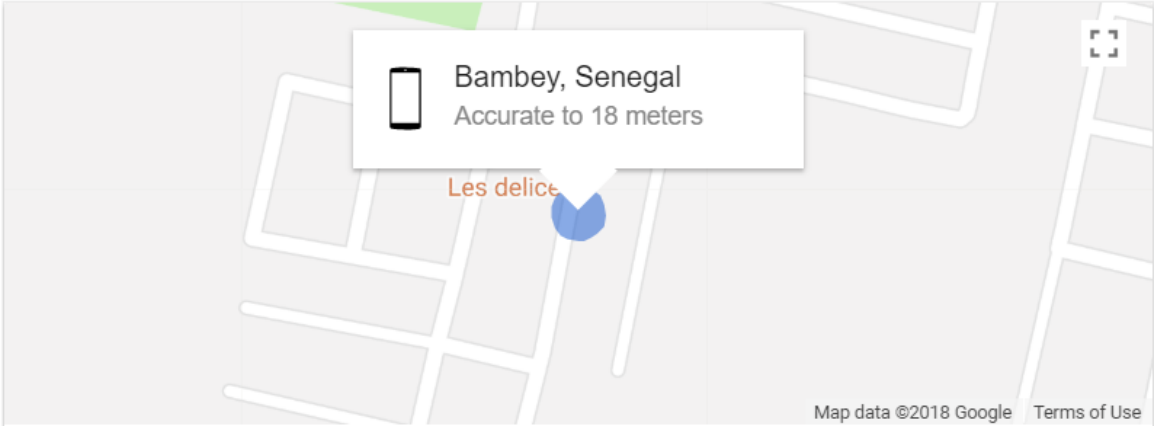
Sécurité des appareils portables

En cas de vol!

Google retrouve votre téléphone!

[All](#) [Videos](#) [Maps](#) [Images](#) [News](#) [More](#) [Settings](#) [Tools](#)

About 5,180,000,000 results (0.32 seconds)



Bambey, Senegal
Accurate to 18 meters

Les delice

Map data ©2018 Google [Terms of Use](#)

 **samsung SM-J250F**
Last synced: Jul 2, 2018

 **Ring**  **Recover**

[Trying to help a friend?](#)

[Feedback](#)

Find your phone - Google Account

<https://myaccount.google.com/intro/find-your-phone> ▼

Lost your **phone**? Try some simple steps, like showing the location or locking the screen, to help you secure it. **Google** [Terms & Privacy](#) [Help](#). **Google** apps.

Contrôle d'accès

Accès Physique



Code



Carte



Biométrie



Face recognition

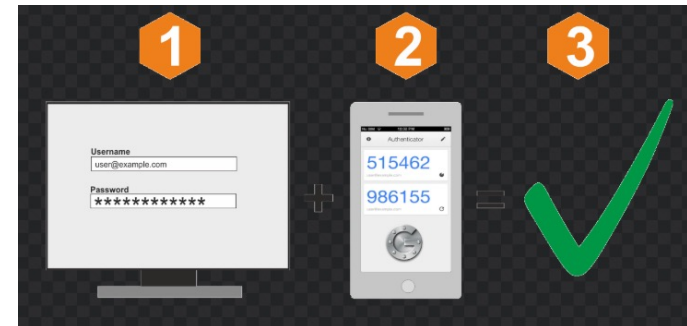
Accès «Logique»



Login+password



Code pin



2-Factor

Protection physique

La protection physique c'est aussi:

- Choix de la salle des serveurs dans le building
- Prévention, Détection et lutte contre les feux
- Prévention des désastres naturels
- Protection du circuit électrique
- ...

Mesures de sécurité informatique

Culture de Securite Informatique

Envoyer un homme sur la lune

Le Président John F. Kennedy a visité le siège de la NASA pour la première fois en 1961. Alors qu'il effectuait cette visite, il se présenta au concierge qui nettoyait le sol et lui demanda ce qu'il faisait à la NASA.

Le concierge répondit:

"J'aide à envoyer un homme sur la lune!"

De toute évidence, le concierge comprenait l'importance de sa contribution. Il croyait sincèrement qu'il était un élément précieux de quelque chose de plus grand que lui-même, et son attitude créait un sentiment de confiance en sa mission.

Il n'était pas seulement un concierge; il était un membre de l'équipe spatiale 1962 de la NASA!



***Comment nous responsabilisons et
motivons chaque employé à faire partie de
l'Equipe de Sécurité***

Culture de sécurité

La sécurité est une affaire de personnes, pas seulement de technique

- Sans une bonne formation, la technologie ne peut pas être efficace
- Les agressions contre le personnel organisationnel, y inclus les agressions directes, sont une tactique courante des agresseurs
- Plus de **la moitié de toutes les failles de sécurité sont le résultat d'une erreur humaine** ou sont compliquées par une erreur humaine
- Une personne peut être **votre plus gros atout ou votre maillon le plus faible** en termes de sécurité



Bénéfices d'une culture de sécurité efficace

- Niveau de sécurité renforcé
- Sûreté améliorée en synergie
- Systèmes de gestion renforcés
- Performance personnelle améliorée, engagement partagé pour la sécurité nucléaire
- **Satisfaction accrue des employés**
- Diminution des coûts



Formation – Développement du Capital Humain



Besoins en formation

Qui doit être formé: ***TOUS***

La formation en sécurité informatique est nécessaire pour:

- Comprendre les exigences de la sécurité informatique et les procédures et comment les appliquer dans le cadre de son travail
- Identification de l'agression et de la menace
 - Menaces internes
 - Ingénierie sociale
- Réduire l'erreur humaine
- Soutien pour la prise des décisions en fonction du risque

Types de formation

- **Formation thématique pour utilisateur:** cours sur des aspects spécifiques de la sécurité pour tout le personnel (utilisation d'e-mails, classification des documents)
- **Formation professionnelle:** la formation des administrateurs de systèmes, les développeurs de logiciels, les administrateurs réseaux, les agents de sécurité, etc..
- **Formation spécialisée en sécurité :** formation ciblée et au niveau d'expert dans le domaine de l'évaluation et de la gestion du risque, de la prévention et de la réponse aux incidents, de l'évaluation de la sécurité informatique.
- **Formation des preneurs de decision:** formation ciblée envers ceux qui établissent les lois et regulations (deputes, maires, ministers, societe civile, etc..) pour que les lois et regulations soient en phase avec les exigences de securite.
- **Formation des agents de la loi:** formation ciblée envers ceux qui appliquent la loi (juges, avocats, policiers, gendarmes, etc.)²⁰

Ces autres personnes a former...

Quelles sont les exigences de formation pour:

- Les contractants
- Les vendeurs
- Les visiteurs
- Hors site/Sur site

Culture de sécurité – Sensibilisation

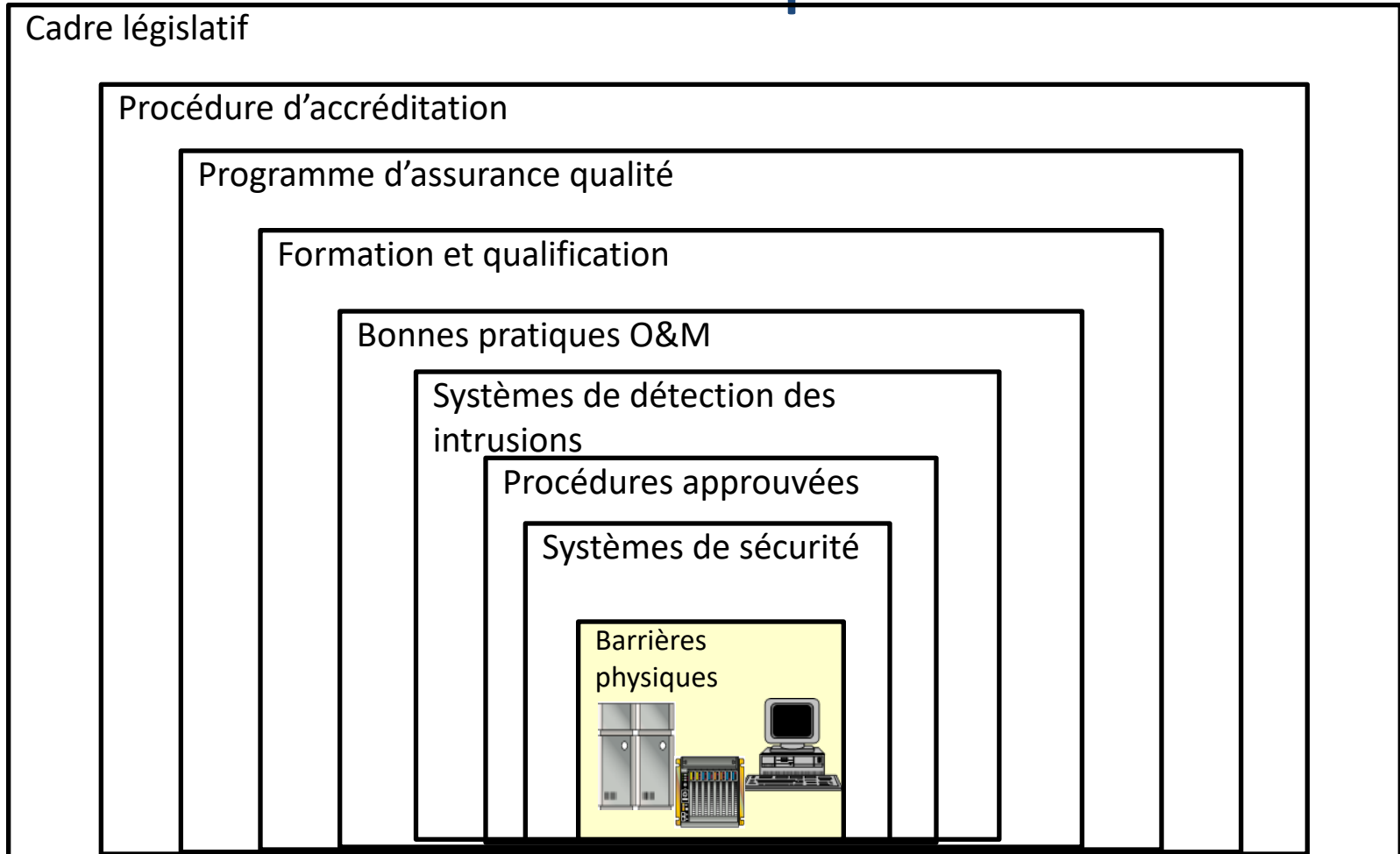
- La sensibilisation sur la sécurité est développée grâce à un ensemble d'activités dans une organisation qui sont conçues pour informer le personnel et accroître la prise de conscience.
- Activités, **mis à part la formation**:
 - Séminaires et présentations
 - **Posters et notices**
 - Discussions du Management
 - **Bulletins d'information et notifications sur la sécurité**
 - Publication des enseignements tirés
 - Avertissements, mesures disciplinaires
 - Tests réguliers



Mesures de sécurité informatique

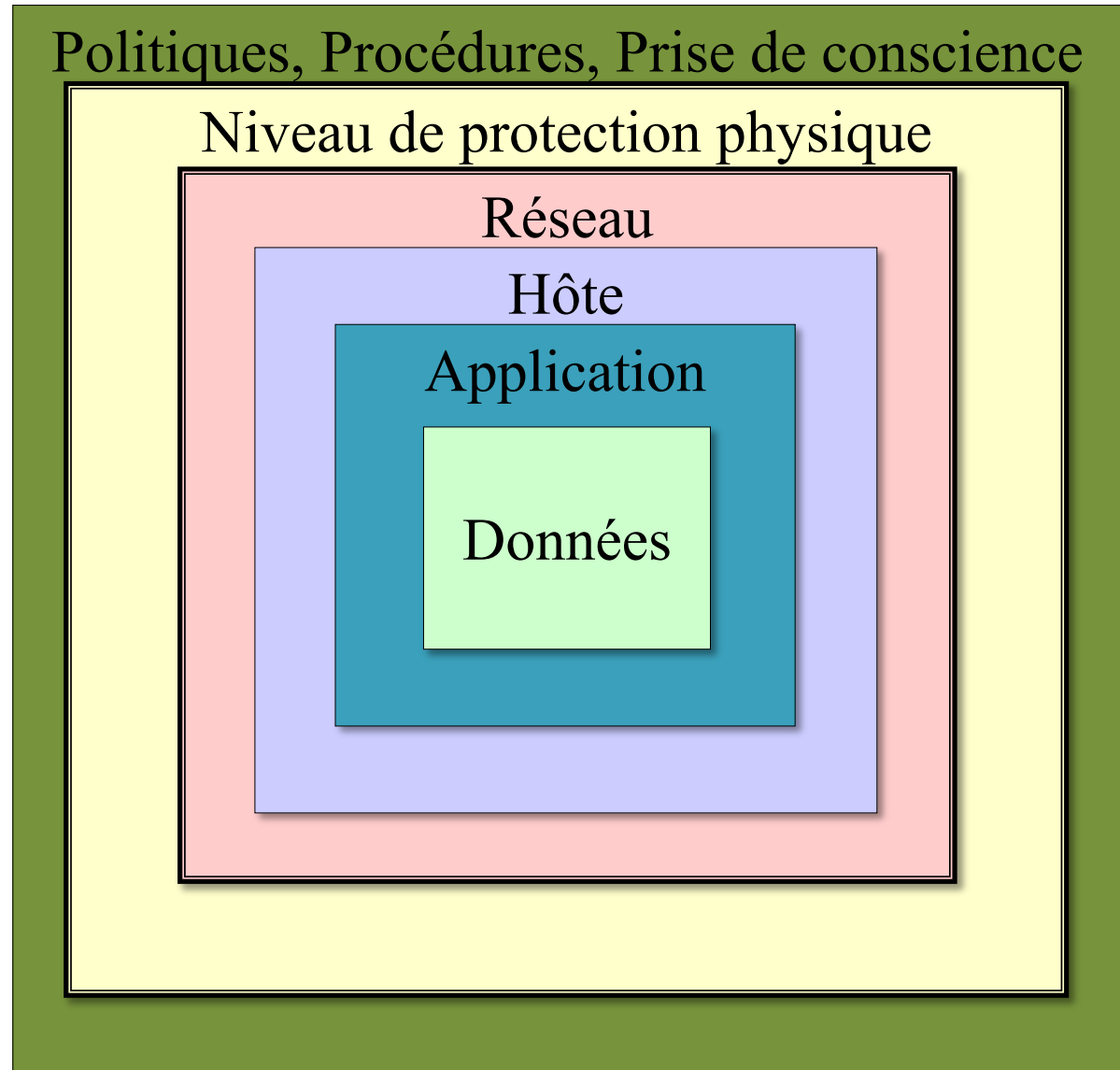
Un TOUT!

Défense en profondeur – structure holistique

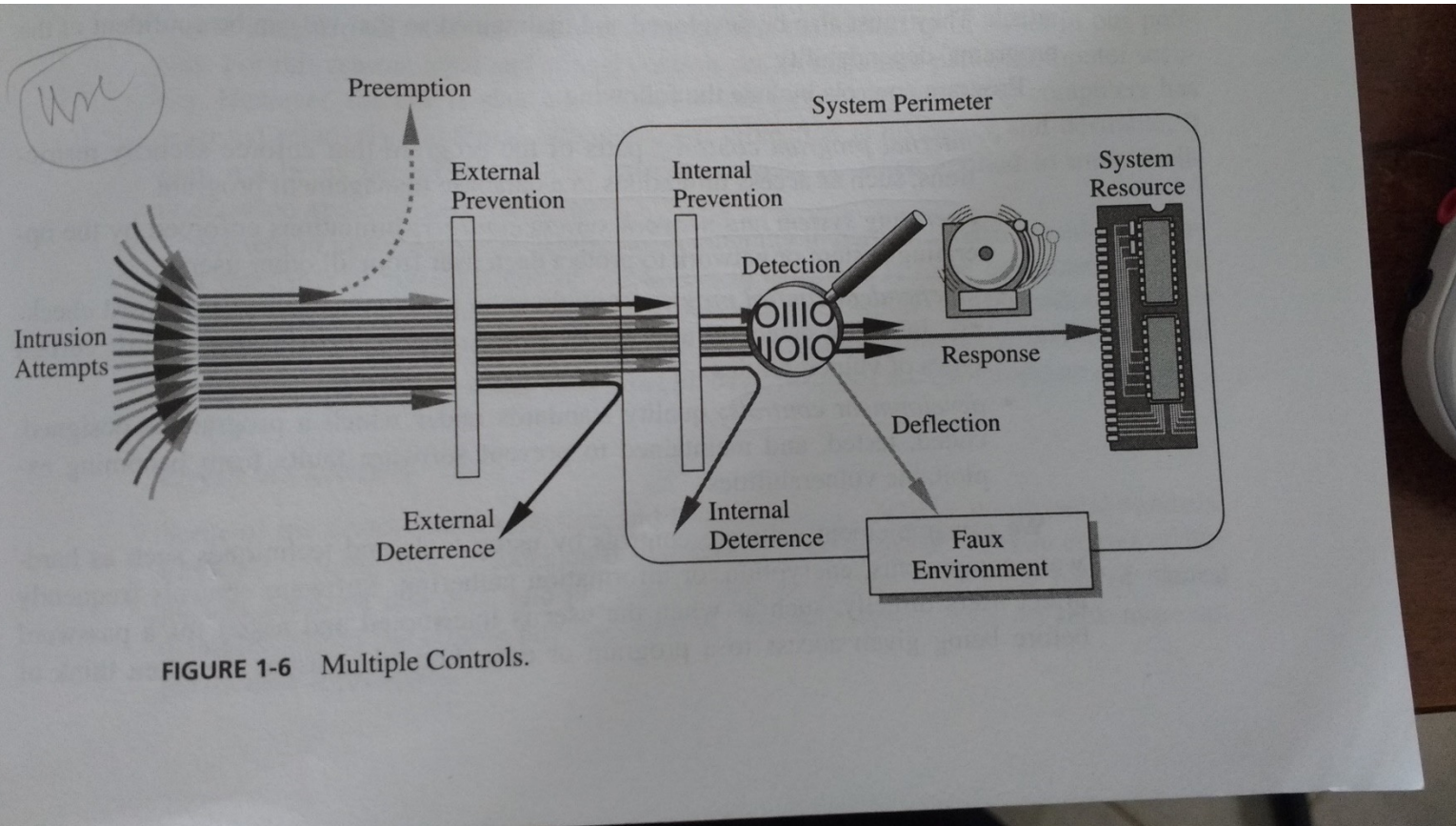


Défense en profondeur – Protection à plusieurs niveaux

Les niveaux de défense sont mis en oeuvre à de multiples niveaux de l'architecture informatique et sont combinés avec les mesures techniques et administratives



Defense in Depth



Mesures de sécurité informatique

Technique

Mesures Technniques

- **Sécurité des applications**
 - Modélisation
 - Développement
 - Déploiement
- **Sécurité des protocoles**
- Architecture des réseaux
- **Contrôles d'accès**
- **Identification, Authentification & Autorisation**
- Techniques de prévention d'attaques
- Techniques de détection d'attaques
- Réponse et mitigation d'une attaque
- Remise en marche
- **Forensique**
- **Audit, Pen-Testing & Continuous Monitoring**

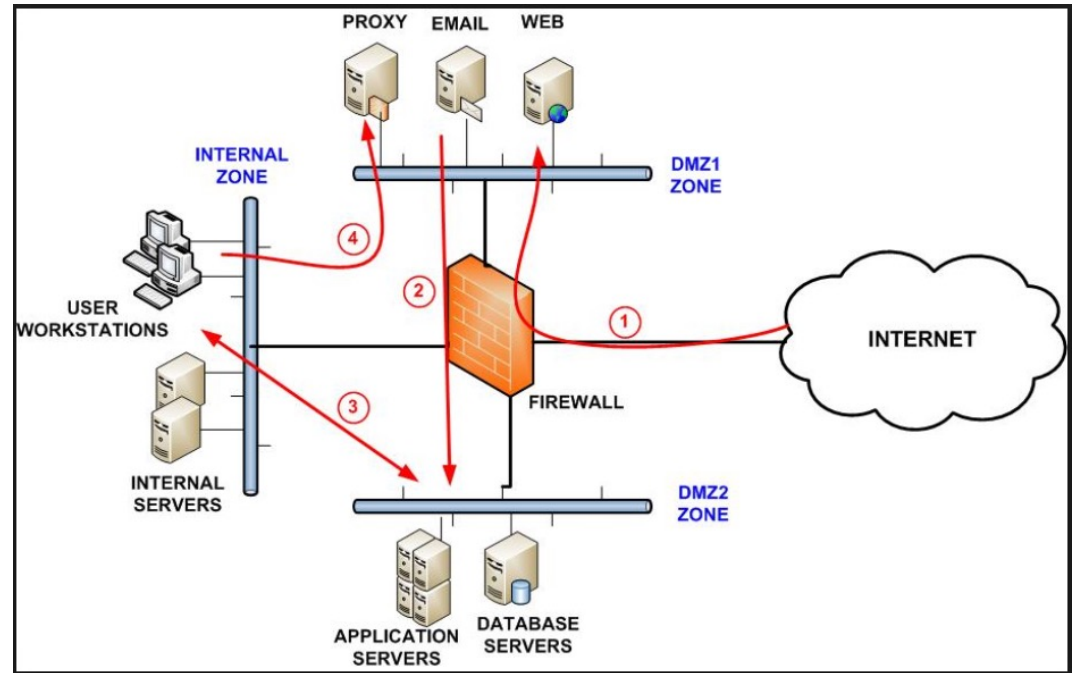
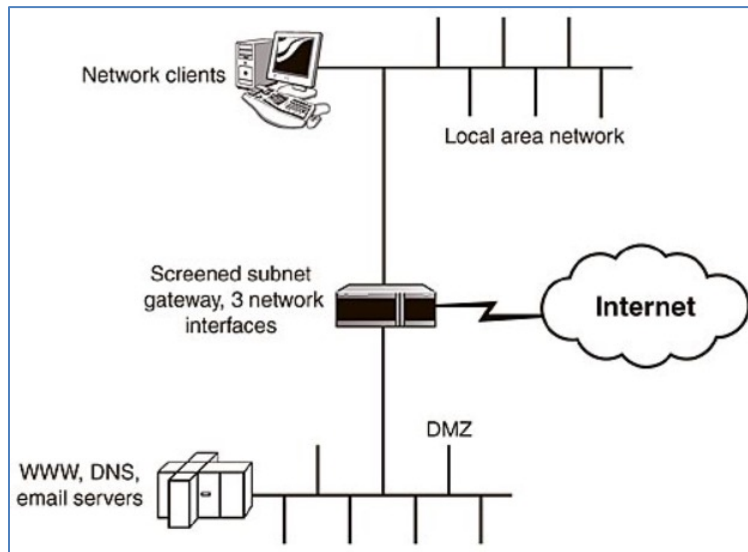
Mesures Technniques

- Best Practices

<https://www.sans.org/reading-room/whitepapers/bestprac/>

Mesures Technniques

- Topologies



Cryptographie

- **Sécurité des applications**
 - Modélisation
 - Développement
 - Déploiement
 - **Sécurité des protocoles**
 - Architecture des réseaux
 - **Contrôles d'accès**
 - **Identification, Authentification & Autorisation**
 - Techniques de prévention d'attaques
 - Techniques de détection d'attaques
 - Réponse et mitigation d'une attaque
 - Remise en marche
 - Forensique
-
- Audit, Pen-Testing & Continuous Monitoring

Protocoles, Information, Communications

- ✓ Virtual Private Network (VPN)
- ✓ Layer 2 Tunneling Protocol (L2TP)
- ✓ Point-to-Point Tunneling Protocol (PPTP)
- ✓ Terminal Access Controller Access Control System (TACACS)
- ✓ Remote Authentication Dial-In User Service (RADIUS)
- ✓ Secure Sockets Layer (SSL)
- ✓ Internet Protocol Security (IPSec)
- ✓ Secure Shell (SSH)
- ✓ Open Systems Interconnection (OSI) model
- ✓ Pretty Good Privacy (PGP)
- ✓ Secure Multipurpose Internet Mail Extension (S/MIME)
- ✓ Hypertext Transport Protocol over Secure Sockets (HTTPS)
- ✓ Transport Layer Security (TLS)

What is SSL/TLS and HTTPS?

SSL is an acronym for **Secure Sockets Layer**. A type of digital security that allows encrypted communication between a website and a web browser. The technology is currently **deprecated** and has been replaced entirely by TLS.

TLS stands for **Transport Layer Security** and it ensures data privacy the same way that SSL does. Since SSL is actually no longer used, this is the correct term that people should start using.

HTTPS is a **secure** extension of HTTP. Websites that install and configure an SSL/TLS certificate can use the HTTPS protocol to establish a secure connection with the server.

What is SSL/TLS and HTTPS?

- The goal of SSL/TLS is to make it **safe and secure to transmit sensitive information including personal data, payment or login information.**
- It's **an alternative to plain text data transfer** in which your connection to a server is unencrypted, and it makes it harder for crooks and hackers to snoop on the connection and steal your data.
- You can tell when a website is using one because **you'll see a little padlock icon** next to the URL in the address bar.

How Do SSL/TLS Certificates Work?

SSL/TLS certificates work by digitally tying a **cryptographic key** to a company's identifying information. This allows them to **encrypt data transfers** in such a way that they can't be unscrambled by third parties.



Visitors computer

Hello, is your connection secure?

Sure, I'm sending my certificate now! 📄



Server



Visitors computer

Great! Ready to establish a safe connection?

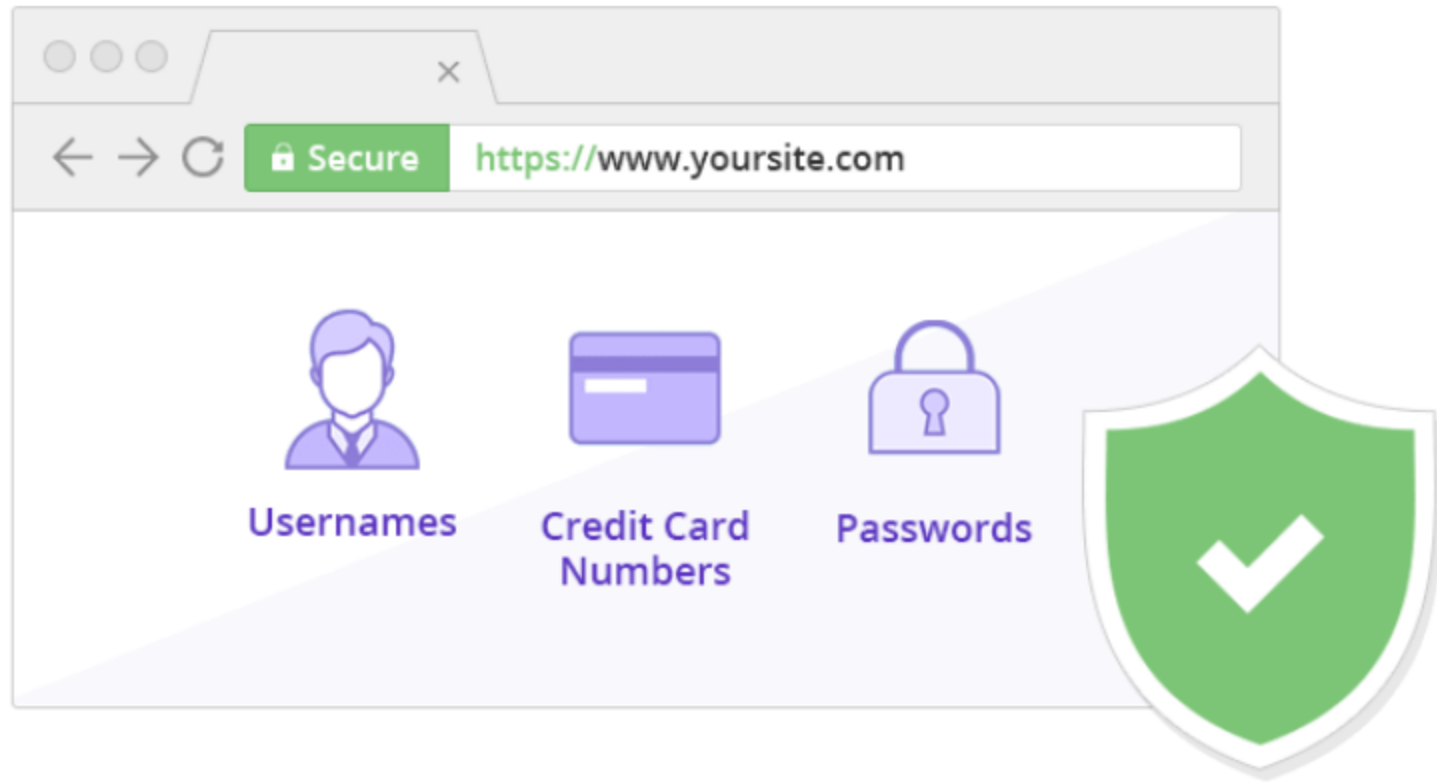
I will encrypt the path now and decrypt it when it's safe!



Server

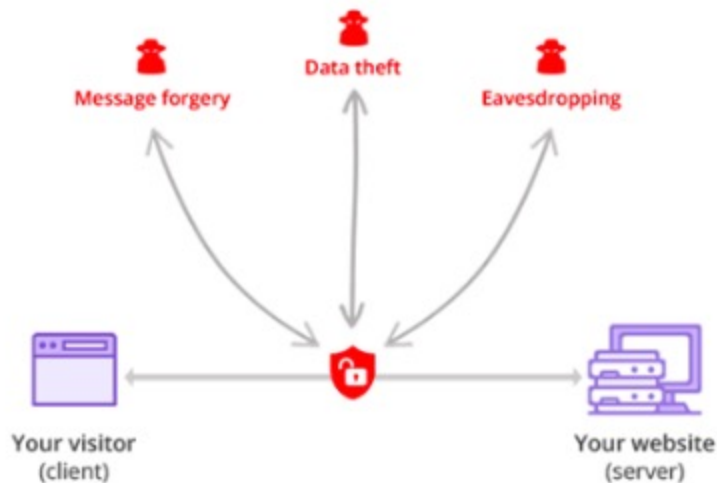
- Private & public keys
- Session key

When and Why is SSL/TLS is a MUST?



How SSL/TLS Relates to HTTPS?

HTTP: No Encryption (no SSL)



HTTPS: Secure Cheap SSL Connection



How does SSH Work?

SSH, or Secure Shell, is a **remote administration protocol** that allows users to control and modify their remote servers over the Internet.

The service was created as a **secure replacement for the unencrypted Telnet** and uses cryptographic techniques to ensure that all communication to and from the remote server happens in an encrypted manner.

It provides a **mechanism for authenticating a remote user**, transferring inputs from the client to the host, and relaying the output back to the client.

How Does SSH Work?

On Linux or Mac, comes installed!

Windows users can use SSH clients like **Putty**

The SSH command consists of 3 distinct parts:

```
ssh {user}@{host}
```

Complete from Crypto Course

IPsec (Internet Protocol Security)

IPsec (Internet Protocol Security) is a **framework** that helps us to **protect IP traffic on the network layer**

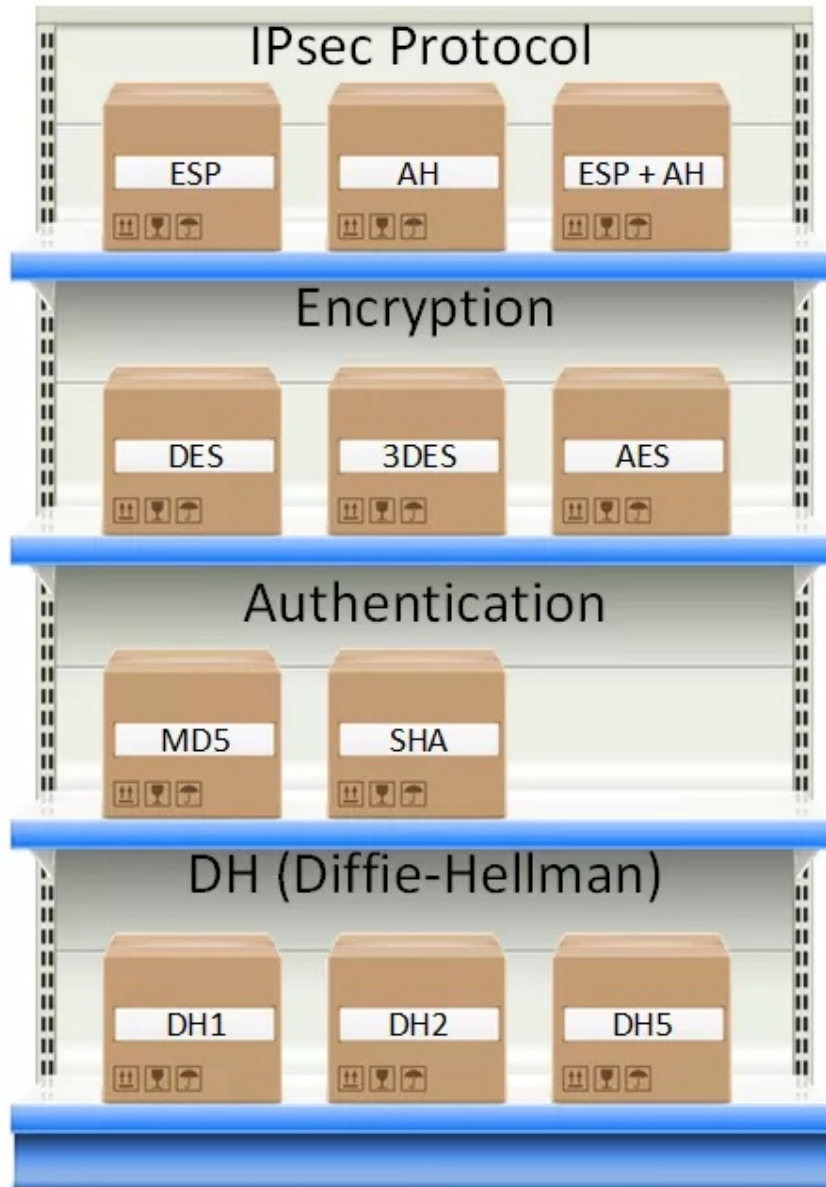
The IP protocol itself doesn't have any security features at all

IPsec can protect our traffic with the following features:

- **Confidentiality**
- **Integrity**
- **Authentication**
- **Anti-replay** (do you remember sequence numbers?)

IPsec (Internet Protocol Security)

Overview



AH (Authentication Header)
ESP (Encapsulating Security Payload)

IPsec (Internet Protocol Security)

IPsec can be used on many different devices, it's used on **routers, firewalls, hosts and servers**.

Here are some examples how you can use it:

- Between two routers **to create a site-to-site VPN that “bridges” two LANs together**.
- Between a firewall and windows host for remote access VPN.
- Between two linux servers to protect an insecure protocol like telnet.

IPsec (Internet Protocol Security)

Phases:

IKE Phase 1: peers negotiate about the encryption, authentication, hashing and other protocols

IKE Phase 2: for management traffic like keepalives

Once IKE phase 2 is completed, we have an IKE phase 2 tunnel (or **IPsec tunnel**) that we can use to protect our user data.

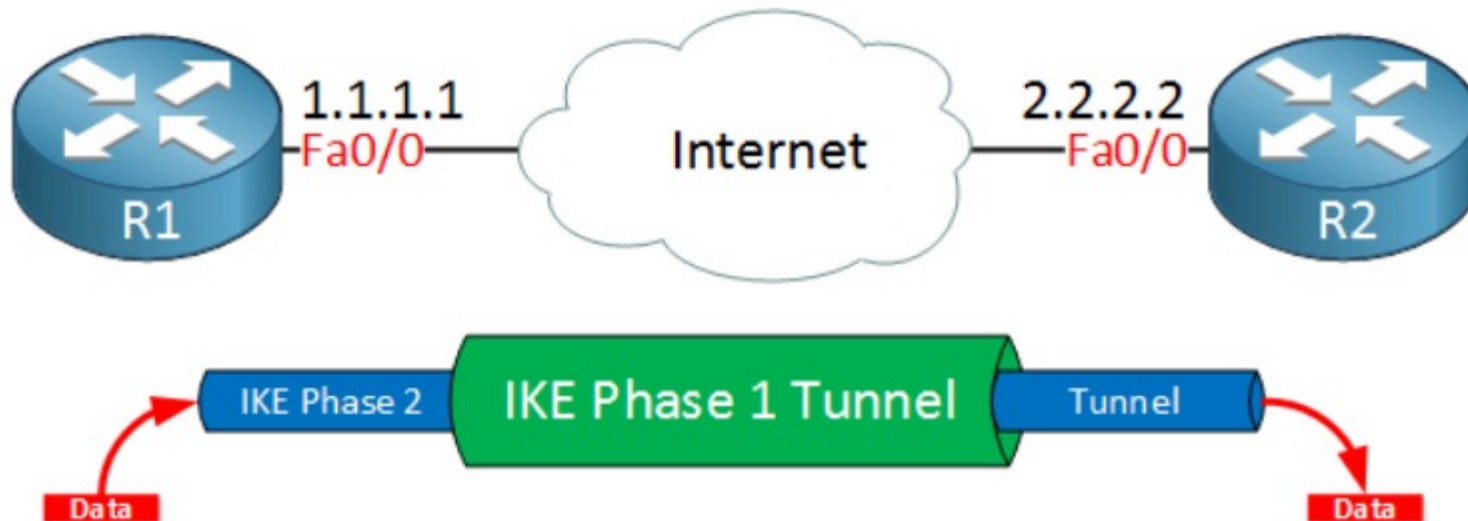
IPsec (Internet Protocol Security)

Phases:

IKE Phase 1: peers negotiate about the encryption, authentication, hashing and other protocols

IKE Phase 2: for management traffic like keepalives

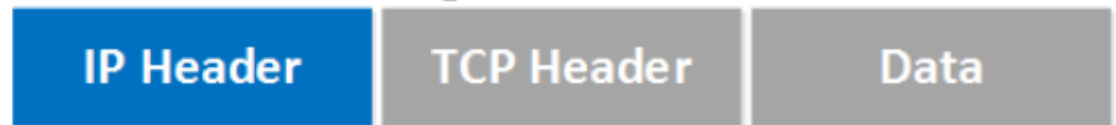
Once IKE phase 2 is completed, we have an IKE phase 2 tunnel (or **IPsec tunnel**) that we can use to protect our user data.



IPsec (Internet Protocol Security)

Transport vs Tunnel

Original IP Packet



AH Transport Mode



AH Tunnel Mode



IDS/IPS

IDS Definition

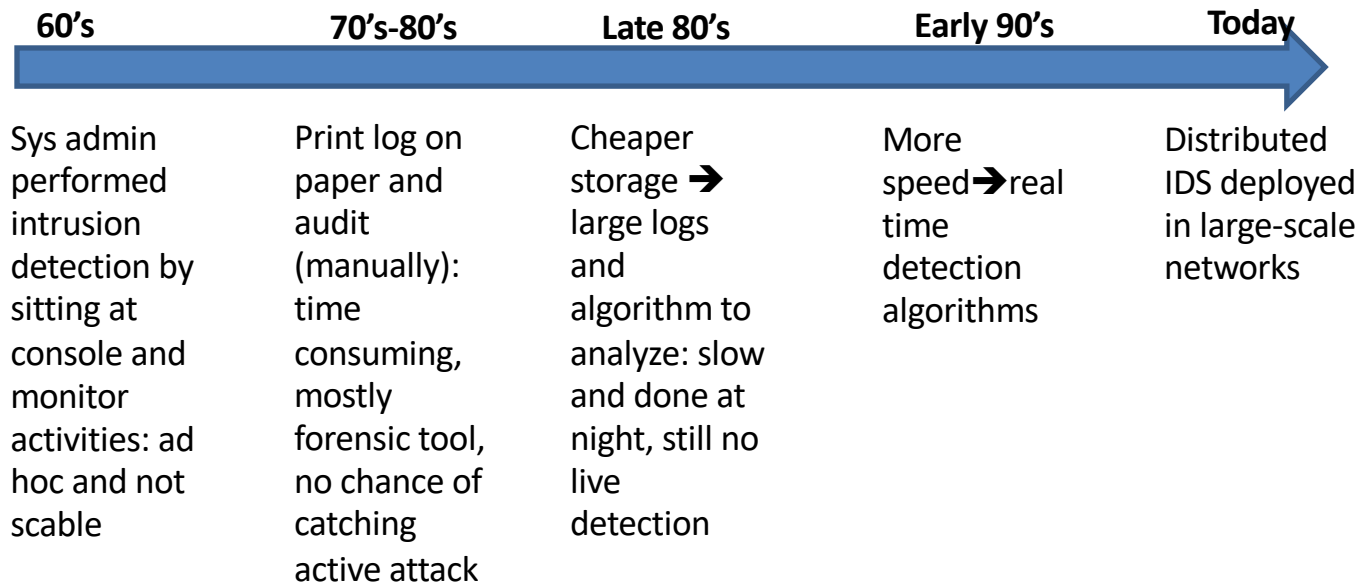
- **What is an IDS?**

- An extra layer of protection
- A device that detects attempted and active misuse
- A device that monitors systems to detect insecure states
- A set of mechanisms put in place to warn of attempted unauthorized access

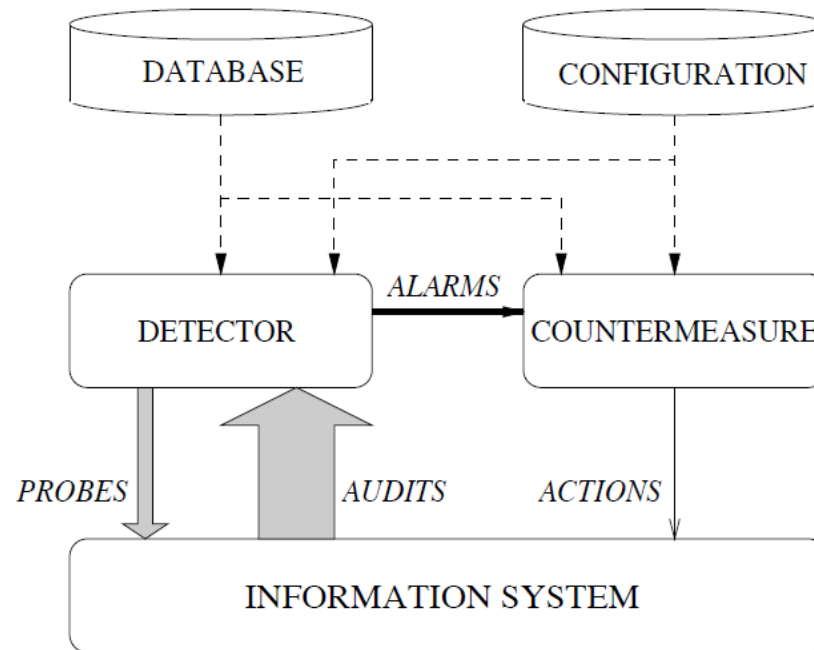


- All of the above

IDS History



A Generic IDS



NOTE: The arrow thickness represents the amount of information flowing from one component to another.

Courtesy to Herve Debar

Intrusions

- **Attempted break-ins:** detected by atypical behavior profiles or violations of security constraints.
- **Masquerade attacks:** detected by atypical behavior profiles or violations of security constraints.
- **Penetration of the security control system:** detected by monitoring for specific patterns of activity.
- **Leakage:** detected by atypical use of system resources.
- **Denial of service:** detected by atypical use of system resources.
- **Malicious use:** detected by atypical behavior profiles, violations of security constraints, or use of special privileges.

Type of IDS

Network-based IDS (NIDS)

- **2nd line of defense**
- **Deploy sensors on strategic points of the network**
 - E.g., Packet sniffing via tcpdump at routers
 - Usually between firewall and system
- **Run on separate, dedicated machines**
 - Attacker has no direct access to it
- **Inspect network traffic**
 - Watch for violation of protocol and unusual connection patterns
 - Watch for portscans, IP spoofing
 - Detect network-specific attacks
- **Monitor user activities**
 - Look into data portion of packets for malicious commands (**deep packet inspection**)

NIDS vs Firewall

- Firewall
 - ◆ Active filtering
 - ◆ Fail-close
- Network IDS
 - ◆ Passive monitoring
 - ◆ Fail-open

Courtesy to to Prof. Angelos Stavrou, GMU

Type of IDS

Host-based IDS (HIDS)

- **3rd line of defense**
- **First area explored in IDS**
 - Remember mainframe when all users were local?
- **Run on the system being monitored**
- **Monitor incoming connections to the host**
 - Detect attempts to unauthorized TCP/UDP ports, detect portscans
 - **Note:** only traffic to this host...not a NIDS
- **Monitor login activities**
 - Detect remote login by attacker
- **Monitor user activities**
 - Root user and system admin activities
 - Simple user activities: analyze shell command, open files
- **Monitor execution of system programs**
 - Trace system calls made by program
- **Monitor the file systems**
 - Detect attempts by attacker to modify files on systems (e.g., disable some detection tools)

Type of IDS

Hybrid IDS

- **Combine**
 - HIDS
 - NIDS

Type of IDS

Kernel-based IDS (KIDS)

- **Similar to HIDS but focus on low level (system level vulnerabilities)**
 - Detect buffer overflow
 - Increase file system protection
 - Limit/monitor root user actions

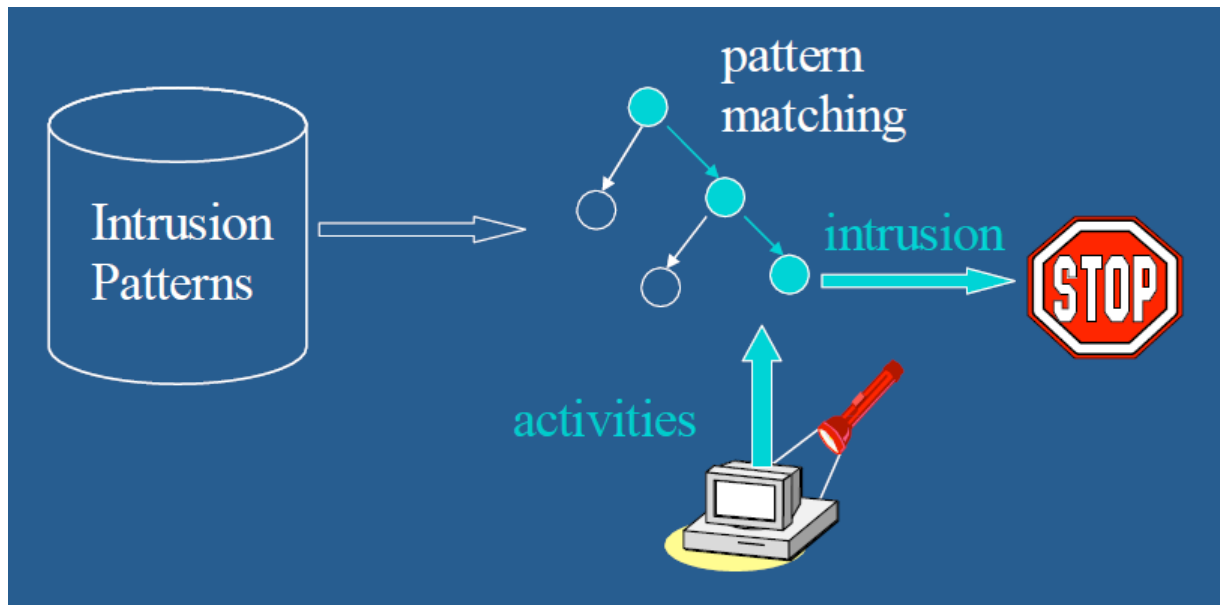
Detection Techniques

Signature

- **Also called “knowledge” or “misuse” detection**
- **Examples:** Snort, RealSecure
- **System is equipped with a number of attack description (signatures)**
 - E.g.: several attempts to connect to ports in system is a typical signature of portscanning
 - Very long entry in address field is a typical signature for buffer overflow
- **Matched against audit data to detect attacks**

Detection Techniques

Signature



Courtesy to to Prof. Angelos Stavrou, GMU

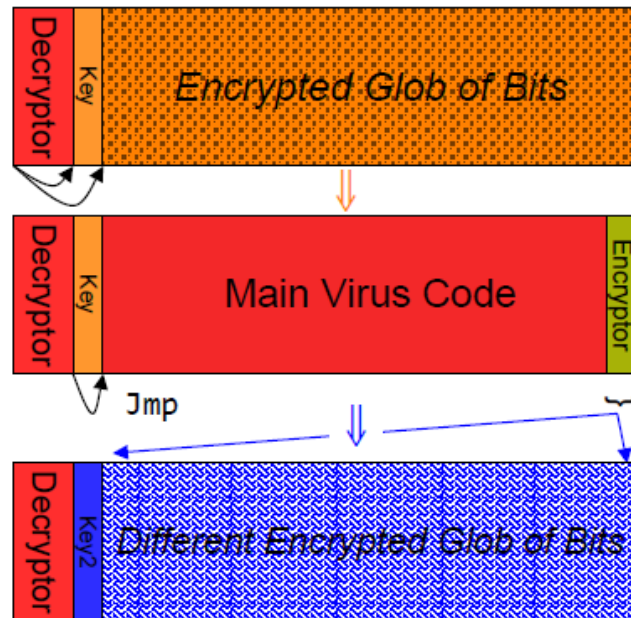
Detection Techniques

Signature

- **Pros:**
 - Very good accuracy: low false alarm rate
- **Cons:**
 - Bad completeness cannot: detect novel attacks
 - need to update/maintain signature database
- **Approaches**
 - Security rule specification (expert system), **pattern matching**, state transition analysis

- **Polymorphic Virus**

- Change nature after every single infection!



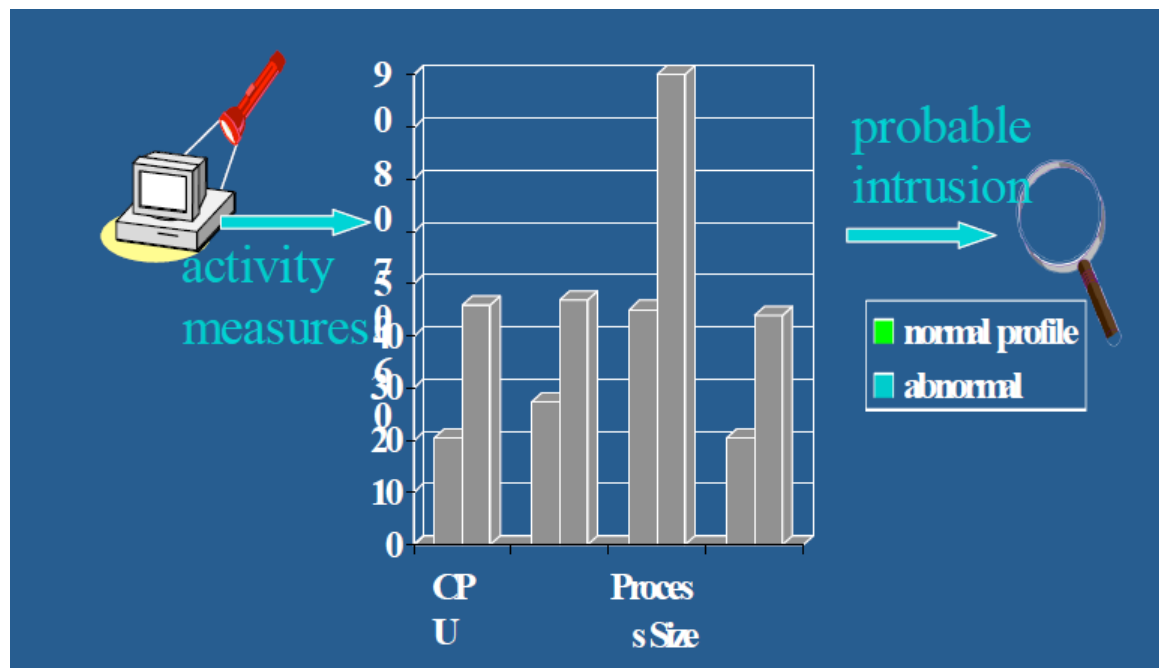
Detection Techniques

Anomaly

- Also called “behavioral”
- **Build models of “normal” behavior of a system**
 - E.g.: user A typically logs at 10 a.m., reads mail, performs database transactions, takes a break between noon and 1 p.m., has very few file access errors, and so on.
- **Any large deviation from the model is thought as anomaly**
 - E.g.: If system notices that user A logs in at 3 a.m., starts using compilers and debugging tools, and has numerous file access errors, it will flag this activity as suspicious.

Detection Techniques

Anomaly



Courtesy to to Prof. Angelos Stavrou, GMU

Detection Techniques

Anomaly

- **Pros:**
 - Good completeness: can detect previously unseen attack
- **Cons:**
 - Bad accuracy: high false alarm rate
- **Approaches**
 - Security rule specification (expert system), statistics, neural network, Bayesian network,

Detection Techniques

Hybrid: Anomaly + Signature

A hybrid intrusion detection system design for computer network security

M. Ali Aydın*, A. Halim Zaim, K. Gökhan Ceylan

Department of Computer Engineering, Faculty of Engineering, Istanbul University, 34320 Avcılar, Istanbul, Turkey

ARTICLE INFO

Article history:

Received 14 March 2007

Received in revised form 15 July 2008

Accepted 30 December 2008

Available online 8 February 2009

Keywords:

Computer networks

Computer network security

Intrusion detection systems

Hybrid intrusion detection system

ABSTRACT

Intrusions detection systems (IDSs) are systems that try to detect attacks as they occur or after the attacks took place. IDSs collect network traffic information from some point on the network or computer system and then use this information to secure the network. Intrusion detection systems can be misuse-detection or anomaly detection based. Misuse-detection based IDSs can only detect known attacks whereas anomaly detection based IDSs can also detect new attacks by using heuristic methods. In this paper we propose a hybrid IDS by combining the two approaches in one system. The hybrid IDS is obtained by combining packet header anomaly detection (PHAD) and network traffic anomaly detection (NETAD) which are anomaly-based IDSs with the misuse-based IDS Snort which is an open-source project.

The hybrid IDS obtained is evaluated using the MIT Lincoln Laboratories network traffic data (IDEVAL) as a testbed. Evaluation compares the number of attacks detected by misuse-based IDS on its own, with the hybrid IDS obtained combining anomaly-based and misuse-based IDSs and shows that the hybrid IDS is a more powerful system.

© 2009 Elsevier Ltd. All rights reserved.

Other Paradigms

Active vs Passive

- **Passive IDS:**
 - Detect, log and send alert
- **Active IDS:**
 - detect and act (e.g., reset connection, reprogram firewall)
 - Sometime called **IPS**

Real-Time vs Offline

- **Real-time IDS**
 - Analyzes the data while the sessions are in progress
 - Raises an alarm immediately when the attack is detected
- **Offline IDS**
 - Analyzes the data after the information has been already collected
 - Useful for understanding the attackers' behavior

IDS Efficiency

- **Accuracy (precision)**
 - Proper detection of attack, absence of false alarm
- **Completeness (completeness)**
 - Ability to detect all attacks (even previously unseen ones)
- **Performance**
 - Rate at which audit events are processed
- **Fault tolerance**
 - Resistance to attack (e.g., DoS)
- **Timeliness**
 - Ability to perform and propagate analysis as quick as possible

False Results

- **Type I Error:**
 - **False Positive Rate:** frequency with which IDS reports malicious activity in error.
 - Also called: “**False Alarm Rate**”, “**inaccuracy**”
 - “Nuisance reports”
 - Nightmare for security admins
 - May cause admins to ignore alerts
- **Type II Error:**
 - **False Negative Rate:** frequency with which IDS fails to raise an alert when malicious activity actually occurs.
 - Also called: “**Missed Detection Rate**”, “**incompleteness**”
 - **Most dangerous errors**
- **IDS tradeoff:**
 - Cannot improve/optimize both at the same time
 - ROC

Cryptographie

Solutions de Sécurité

- User Education
- Access Control
- Data Protection
- Communication Security
- Application Security
- Intrusion Detection/Prevention
- Secure Programming
- Organizational Security
- Forensics



Cryptography



Machine Learning
Artificial Intelligence

Cryptographie

- Un peu d'histoire
- One-Time-Pad
- Chiffrement symétrique
 - Block Cypher
- Chiffrement asymétrique
 - Bases mathématiques
 - Diffie-Hellmman
 - El Gamal
- MAC
- Fonction de hashage
- Signatures

Un Peu d'Histoire

- Cryptographie
 - « *Crypt* » = secret
 - « *Graphia* » = écrire
- **L'ère du « papier + encre »**
 - Envoie de messages secrets depuis l'antiquité
 - Il y'a environ 2000 ans
 - **Julius Caesar: permutation de l'alphabet en décalant chaque lettre d'un nombre fixe de positions**
 - Exemple: Décalage de 3 position
 - **E(cryptographie) = ???**
 - Dans les années 1800: l'arrivée du télégraphe amplifie les besoins en crypto (militaire et diplomatie)

Un Peu d'Histoire

- Cryptographie
 - « *Crypt* » = secret
 - « *Graphia* » = écrire
- **L'ère mécanique**
 - Seconde guerre mondiale: les Allemands créent la machine Enigma
 - Grande coalition «scientifique » pour casser Enigma (Anglais, Américains, Polonais)
 - Craquage de Enigma inclut: Alan Turing
 - Beaucoup de technique (dont espionnage et ingénierie sociale)
 - **A écourté la guerre d'une année!**

Un Peu d'Histoire

- Cryptographie
 - « *Crypt* » = secret
 - « *Graphia* » = écrire
- **L'ère moderne**
 - Après la guerre
 - Précurseur: **Claude Shannon analysa la sécurité de One-Time-Pad!**
 - Début des années 1970: NIST standardise DES (Data Encryption Standard)
 - Largement utilisé par les banques
 - Début des années 1970: explosion de la théorie du calcul crypto
 - Une science qui a beaucoup évolué
 - Aujourd'hui beaucoup d'activités sur la « **cryptographie quantique** »

Terminologie

- Acteurs
 - Alice, Bob, Eve, Mallory
- Chiffrement/Déchiffrement
 - Se focalise sur la confidentialité
- Modèles de chiffrement
 - Clefs symétriques/asymétriques
- Texte Clair vs Texte Chiffre (crypte)

Définition

- **Kerkhoff**

« ... les systèmes cryptographiques **doivent rester sécurisés même après que l'attaquant découvre tous les détails internes** du système. La clef doit être **la seule chose secrète** et le système doit être conçu pour faciliter le changement des clefs qui ont été volées... ».

→ **Pas de sécurité par obscurité!**

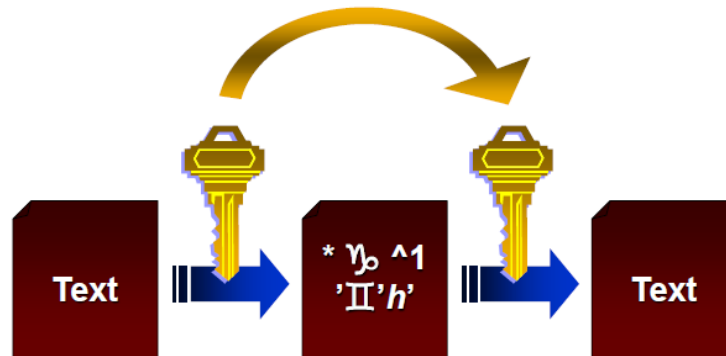
Modèle d'attaquants (Eve)

- Capabilités de Eve
 - Intercepter un seul message (crypte) et veut retrouver le texte clair correspondant (peut avoir des informations partielles sur le message original)
 - Utiliser le système de chiffrement pour crypter et étudier un certain nombre de messages clairs $M_1, M_2, \dots, M_n$, et deviner le message clair d'un message crypte donné C (attaque par texte clair choisi)
 - Étudier le déchiffrement d'un certain nombre de messages cryptés $C_1, C_2, \dots, C_n$, et deviner le message clair d'un message crypte donné C (attaque par texte crypte choisi)
 - Combinaison des précédentes

Chiffrement Symétrique

Solutions cryptographiques

Symétrique



- Chiffrement
 - Génération de clef: Alice et Bob se **retrouve** et choisissent une clef (aléatoire) commune dénommée K
 - Algorithme de chiffrement: $C = M \oplus K$
 - Algorithme de déchiffrement: $M = C \oplus K$

• **Question:** quel principe de sécurité est en considération?

One-Time-Pad

- Chiffrement idéal
 - Clef de même longueur que le message
- Résumé
 - Génération de clef: Alice et Bob choisissent une clef (aléatoire) commune dénommée K
 - Algorithme de chiffrement: $C = M \oplus K$
 - Algorithme de déchiffrement: $M = C \oplus K$
- Claude Shannon
 - OTP est un système de chiffrement de sécurité parfait (dans le sens...l'interception d'un message crypté n'augmente en rien l'avantage de Eve)

Chiffrement Symétrique

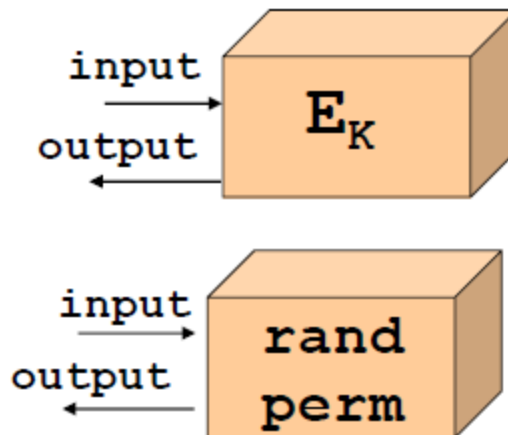
- Composante principale du chiffrement symétrique (moderne)
- Une fonction $E: \{0,1\}^k \times \{0,1\}^n \rightarrow \{0,1\}^n$
- Une fois K fixée, on a
 $E_k: \{0,1\}^n \rightarrow \{0,1\}^n$ définie par, $E_k(M) = E(K,M)$
- Trois propriétés
 - **Exactitude:** $E_k(M)$ une permutation
 - **Efficacité:** Chiffrement et déchiffrement en temps records
 - **Sécurité:** Un adversaire sans la clef ne peut pas distinguer $E_k(M)$ d'une autre permutation

Chiffrement Symétrique

- Critère de **Sécurité**:

- Deux boxes sont présentés a l'adversaire: l'un implémente $E_k(M)$ l'autre implémente une permutation aléatoire
- L'adversaire ne connaît pas a priori lequel des boxes fait quoi
- L'adversaire peut interroger chaque boxe et analyser la réponse
- Son objectif est de deviner lequel correspond a $E_k(M)$

??? Which is E_K ???



Sécurité = l'adversaire ne peut pas faire mieux que quelqu'un qui choisit de manière aléatoire avec probabilité $\frac{1}{2}$, $\frac{1}{2}$.

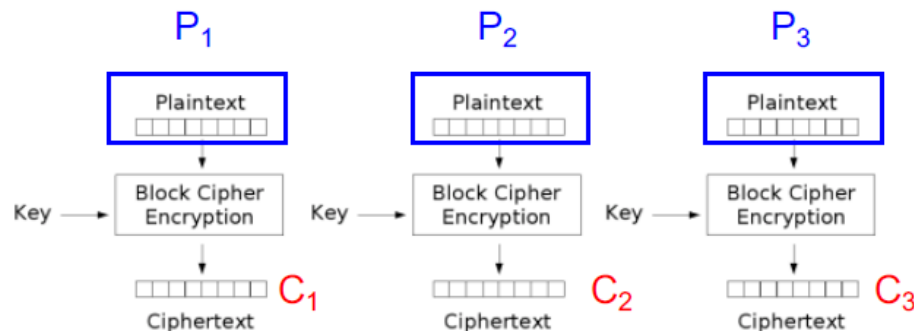
Longueur Clef...

- **Longueur Clef = Longueur n'est pas vivable**
 - **On ne connaît pas a-priori le message (i.e., sa longueur a l'avance)**
 - Message peut être très long (un livre)
 - ...
 - **On risque de passer tout le temps à chiffrer et déchiffrer!**
- ➔ **Fixer la longueur de la clef...et diviser le message en blocs!**

Chiffrement en Bloc

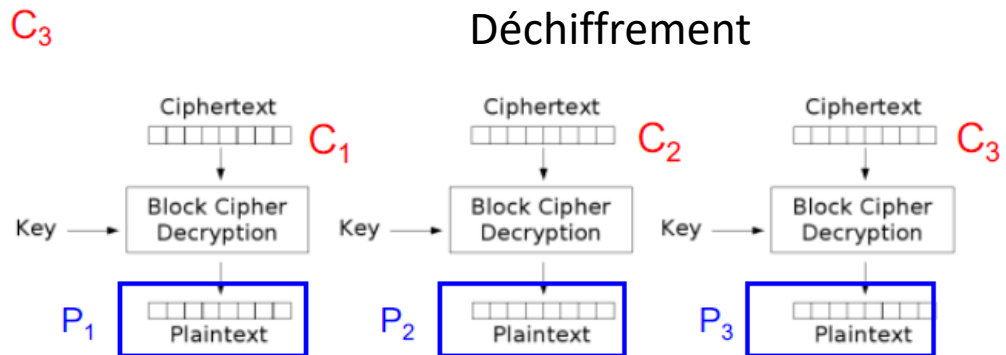
- **Exemple: ECB mode (Electronic Code Book)**

- Divise le message en blocs $P_1, P_2, \dots$
- Chaque bloc correspond a un code par lequel il est remplacé
- Chaque bloc est crypté de manière indépendante aux autres



Electronic Codebook (ECB) mode encryption

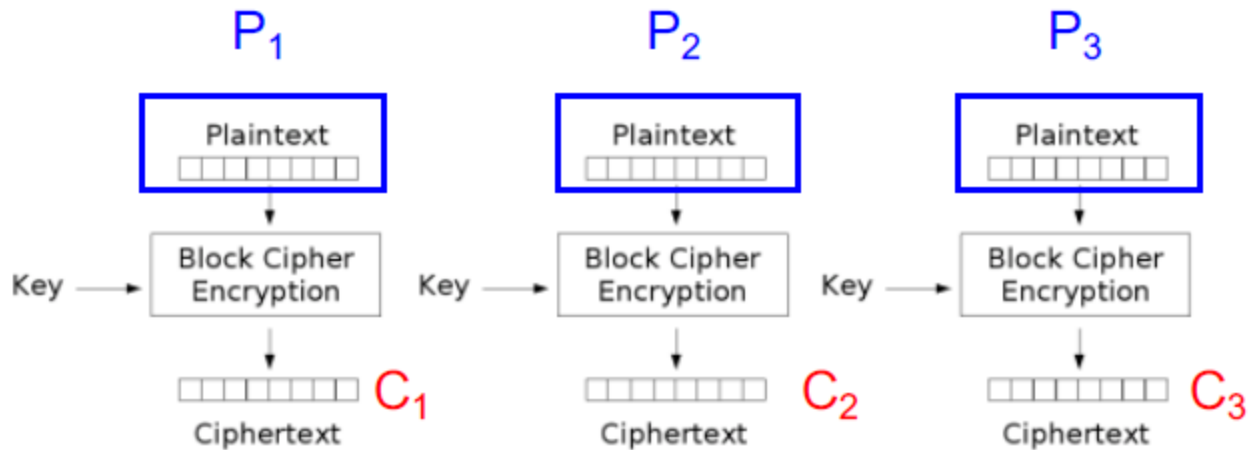
Chiffrement



Electronic Codebook (ECB) mode decryption

Chiffrement en Bloc

- Exemple: ECB mode (Electronic Code Book)
- Problèmes ???



Electronic Codebook (ECB) mode encryption

Chiffrement en Bloc

- **Exemple: ECB mode (Electronic Code Book)**
 - Chaque bloc est déterministe
 - Le même message a toujours le même texte cypher
 - Adversaire peut gagner un avantage en utilisant une attaque par textes clairs choisis.
 - **Comment?**

$$A \text{ xor } B = 0$$

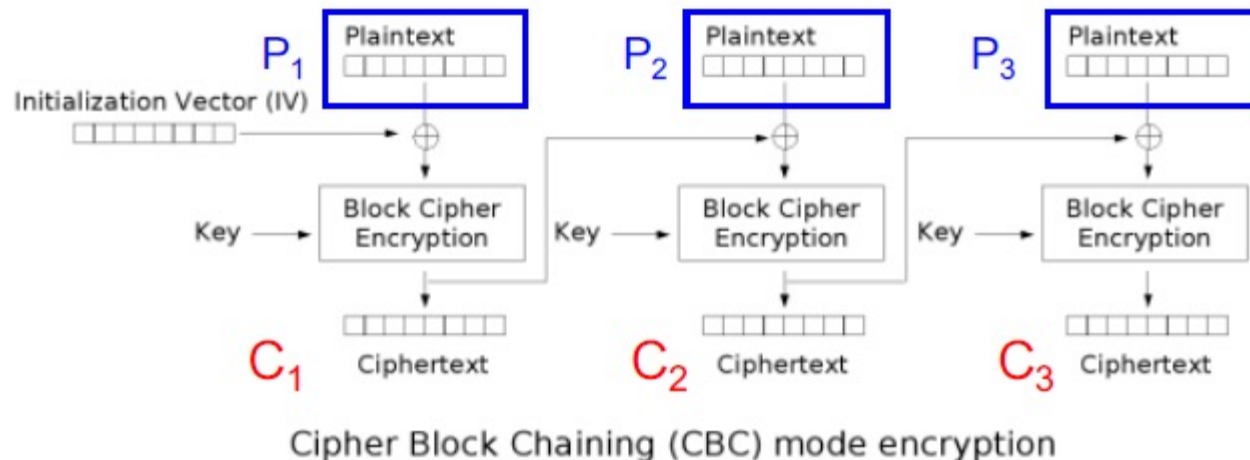
$$A \text{ xor } K = C$$

$$C \text{ xor } B = K$$

Chiffrement en Bloc

- **Exemple: CBC mode (Cypher Bloc Chaining)**

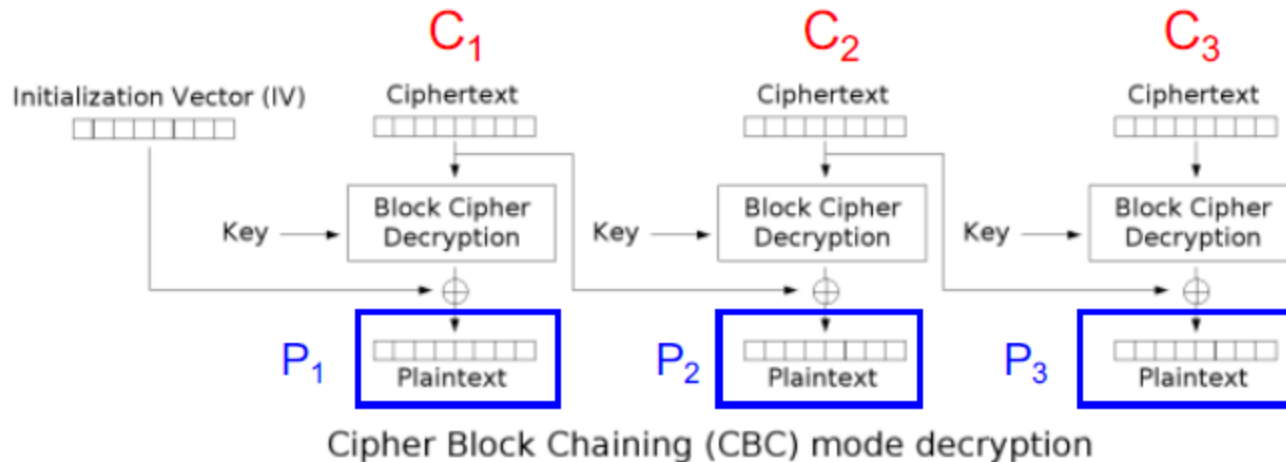
- Diviser le message en bloc $P_1, P_2, \dots$
- Choisir un vecteur initial aléatoire: IV
- Chiffrer en chaîne



- Texte chiffré final: $(IV, C_1, C_2, \dots, C_n)$

Chiffrement en Bloc

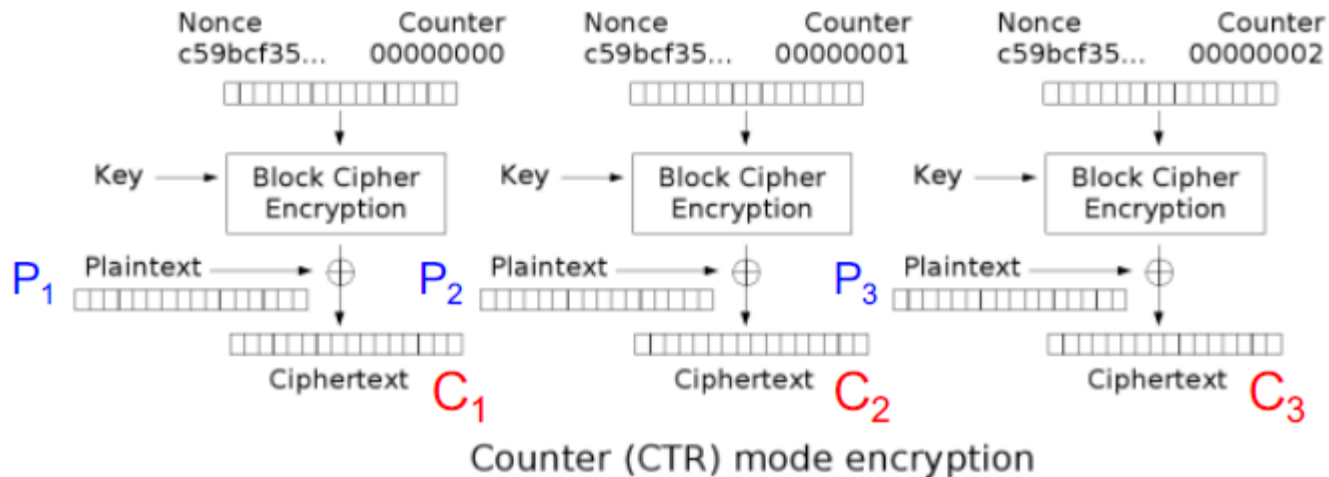
- Exemple: CBC mode (Cypher Bloc Chaining)
- Déchiffrement



Chiffrement en Bloc

- **Exemple: Counter mode (CTR)**

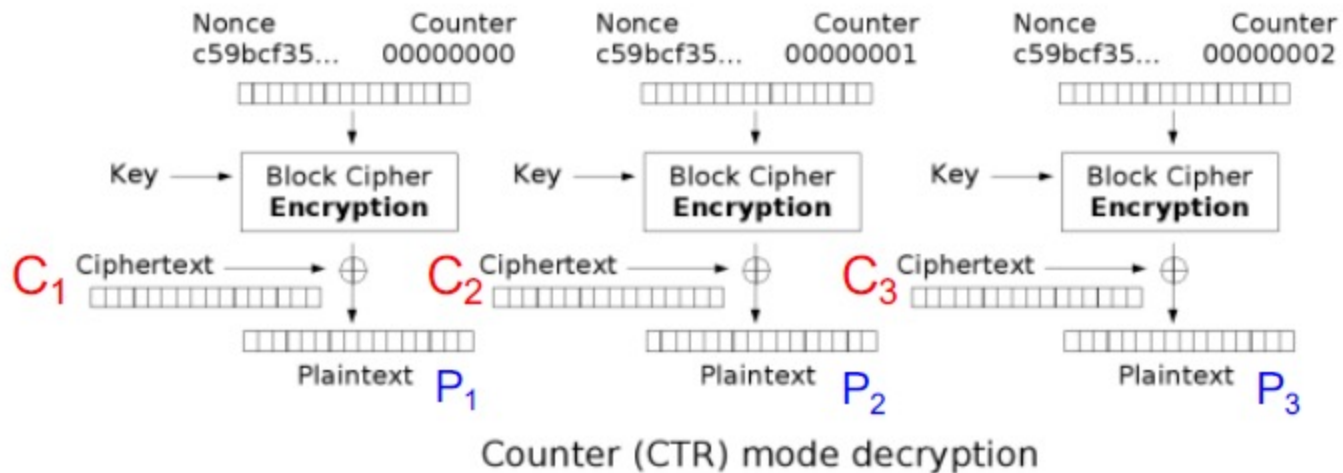
- Diviser le message en bloc $P_1, P_2, \dots$
- Choisir un vecteur initial: IV (pour chaque chiffrement)
- Déclencher un compteur



Chiffrement en Bloc

- Exemple: Counter mode (CTR)

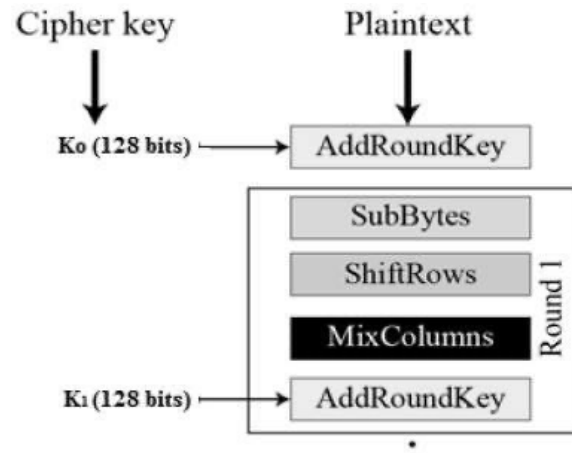
- Déchiffrement



- Comme un chiffrement!

Chiffrement en Bloc

- **Exemple: AES (Advanced Encryption Standard)**
 - Standard NIST (2001)
 - Joan Daemen & Vincent Rijmen, 1997 (Belgique)
 - Taille des bloc: 128bits
 - Tailles clefs: 128, 192 ou 256 (aujourd'hui 256)
 - Conçu pour être très rapide (software & hardware)
 - **Pas de preuve de sécurité, mais tjrs pas d'attaques réussies**



Chiffrement en Flux

- Chiffrement en Flux (stream cypher)
 - Similaire a One-Time-Pad
 - Bits (clef) viennent d'un **générateur de nombres aléatoires (GNA)**
 - Etant donnée la valeur initiale
 - GNA produit une série de bit aléatoirement
 - Est-ce que GNA est vraiment aléatoire?
→ générateur de nombres pseudo-aléatoires
- Chiffrement:
 - Choisir vecteur initial IV
 - $E(K,M) = \text{GNA}(K,IV) \oplus M$

Chiffrement en Bloc

Table 8.1 A Comparison of Symmetric Key Algorithms

Algorithm	Cipher Type	Key Length
DES	Block	56 bits
Triple-DES (3DES)	Block	168 bits
AES (Rijndael)	Block	128–256 bits
Blowfish	Block	1–448 bits
IDEA	Block	128 bits
RC2	Block	1–2048 bits
RC4	Stream	1–2048 bits
RC5	Block	128–256 bits
RC6	Block	128–256 bits
CAST	Block	128–256 bits
MARS	Block	128–256 bits
Serpent	Block	128–256 bits
Twofish	Block	128–256 bits

Problème avec Chiffrement Symétrique

- Alice et Bob doivent au préalable partager un secret!
 - Peut poser problème!

➔ Chiffrement Asymétrique

Chiffrement Asymétrique

Solutions cryptographiques

Asymétrique

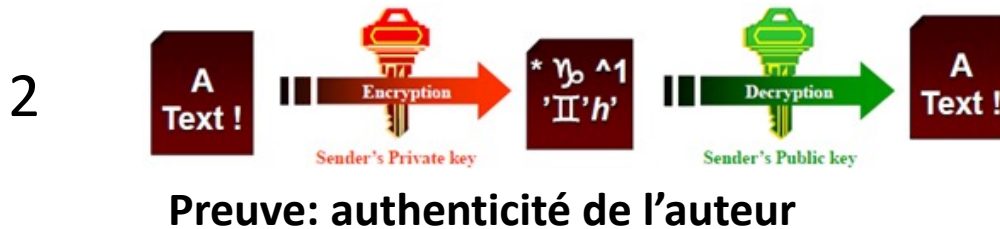
- Pair de clef
 - **Privée** (gardée secrète)
 - **Publique** (disponible a tout le monde)
 - Impossible de retrouver l'une (privée) a partir de l'autre (publique)
- Pas besoin de partager un secret commun (au préalable)



Solutions cryptographiques

Asymétrique

- Deux mode d'emploi



➔ Signature digitale (à compléter)

Crypto a Clef Publique

- Alice crée deux clefs:
 - Une clef privée (gardée jalousement)
 - Une clef publique (mise sur la place publique)
 - Si Bob veut envoyer un message M a Alice
 - Trouve la clef publique de Alice
 - Encrypted le message M avec cette clef et envoie a Alice
 - Alice décrypte le message avec sa clef privée
 - Seuls Alice et Bob connaissent le message original M

Clef Publique

```
AAAAB3NzaC1yc2EAAAABJQAAAQEAoV8pvlRjkALhfGTSQDcowhlQwjxgsjqc+ug1  
go+6sCd01b94o2Ac86gKEH5VDWCiF4YlulNDBEp11DrOn3783b1JVd1hETIJnW6k  
aZ7yhg+mThvgcKs3/rvcuqmxoZDKu04m9wDaSM+C5o7cTsQDX9ogXKIE72ndzgwz  
eirliYtNc0uZqURTIpWgCqnlo7P96bd1oJqxNURTPR3jF5KslMuilnFIIQ5H//P  
VhU0fW5iaSDkOxMuBvLV+hytinWkWuU6PwbO0+ER6m8gH5G899XxskojnhhHqGMn  
2xzy2YtUA8luGqpedhEtQuFeft0voQHfW74FurAR7aLwCOFyQ==
```

Mathematical Background

Chiffrement Asymétrique

- Bases Mathématiques: **Nombre Premier!**
 - Définition? Comment savoir si un nombre est premier?
 - Divisible que par 1 et par lui-même

- **Théorème de Fermat:**

Si p est premier et $0 < a < p$, alors $a^{p-1} \equiv 1 \pmod{p}$

- **Test de primalité:**

Si pour un nombre aléatoire a tel que $0 < a < p$, on a $a^{p-1} \equiv 1 \pmod{p}$, alors p est probablement premier!

- **Choisir un grand nombre premier...**

- Choisir un nombre de taille désirée
- Tester s'il est premier
- Répéter (trouve un nombre premier « en n iterations »)

- **Note:** fraction de nombre premier de taille n (bits) est $1,44/n$

Chiffrement Asymétrique

- Bases Mathématiques: **Exponentiel (modulo)**
 - Calculer $a^b \bmod p$ pour un certain a, b, p
 - Approche naïve:
 - Répéter la multiplication: $a^2 \bmod p, a^3 \bmod p, \text{etc...}$
 - Cout: linéaire en b donc exponentiel avec la taille de b
 - Calcul des puissances de 2: $a^2 \bmod p, a^4 \bmod p, a^8 \bmod p, a^{16} \bmod p$

- Maintenant

$$a^{25} = a^{11001_2} = a^{10000_2} \cdot a^{1000_2} \cdot a^{1_2} = a^{16} \cdot a^8 \cdot a^1.$$

- Calcul: multiplier par a^i si élément $b_i = 1$
 - Complexité: $O(\log^2 p \log b)$
 - Calculer le **logarithme discret** est considéré comme difficile
 - **Etant donnés $p, g, g^x \bmod(p)$, trouver x ?**
 - Pas de méthodes efficace pour le faire!

Diffie-Hellman

- Whit Diffie and Marty Hellman (années 1970)
- **Comment choisir un commun secret sans se rencontrer?**
 - Choisir un grand nombre premier p (pas besoin que ca soit secret)
 - Choisir un nombre g tel que $0 < g < p$ (pas besoin que ca soit secret)
 - Alice choisit un secret a tel que $0 \leq a < p - 1$ et calcule $A = g^a \bmod p$
 - Bob choisit un secret b tel que $0 \leq b < p - 1$ et calcule $B = g^b \bmod p$
 - Alice annonce A et garde a comme secret
 - Bob annonce B et garde b comme secret
 - Alice utilise B et a pour calculer $S = B^a \bmod p$
 - Bob utilise A et b pour calculer $S = A^b \bmod p$
- Remarque: S est un commun secret
$$B^a = (g^b)^a \bmod p = (g^a)^b \bmod p = A^b$$

Diffie-Hellman

- Analyse
 - Toutes les échanges se font en public
 - Seuls Alice et Bob connaissent le secret S
 - Sécurité de DH:
 - Fonction: $f(x) = g^x \bmod p$
 - Facile de calculer f
 - Difficile d'inverser f
- DH permet a Alice et Bob de créer un secret commun mais n'est pas un protocole de clef publique...mais peut servir pour cela!

ElGamal

- Taher ElGamal (1985)
- Basée sur DH
- Approche:
 - Paramètres du système: p, g ; p est un grand nombre premier et $0 < g < p$ (comme dans DH)
 - Bob choisit un secret b tel que $0 \leq b < p - 1$ et calcule $B = g^b \bmod p$
 - Bob publie (B, g) comme sa clef publique et garde b comme sa clef privée.
 - Quand Alice veut envoyer m à Bob
 - Choisit un nombre aléatoire r
 - Calcule et envoie $(R, S) = (g^r \bmod p, m \times B^r \bmod p)$
 - Pour décrypter (R, S) , Bob calcule $R^{-b} \times S \bmod p$
- Ca marche?
Note: $R = g^r \bmod p$ et $S = m \times B^r \bmod p$
$$R^{-b} \times S = (g^r)^{-b} \times m \times (g^b)^r = g^{-rb} \times m \times g^{rb} = m \pmod{p}$$

Comment Créer Une Paire de Clefs? RSA (Rivest, Shamir,Adleman)

Bob choisit les nombres premiers p , q et calcule $n = pq$

$\phi(n) = \phi(p) \phi(q) = (p - 1) (q - 1)$ (indicatrices d'Euler)

Choisir e , tel que $\text{pgdc}(e, \phi(n)) = 1$ (clef publique)

Calculer la clef de decryption (privee), d , par

$$ed \equiv 1 \pmod{\phi(n)}$$

Bob: publie sa clef publique: (e, n)

garde sa clef privee: (d, n)

Remarque: p et q sont oublies!

Encryption: $C = M^e \pmod{n}$

Decryption: $M = C^d \pmod{n}$

Example

$P = 61$ $\leq$ first prime number (destroy this after computing E and D)
 $Q = 53$ $\leq$ second prime number (destroy this after computing E and D)
 $PQ = 3233$ $\leq$ modulus (give this to others)
 $E = 17$ $\leq$ public exponent (give this to others)
 $D = 2753$ $\leq$ private exponent (keep this secret!)

Your **public key** is (E, PQ) .

Your **private key** is D .

The encryption function is: $\text{encrypt}(T) = (T^E) \bmod PQ$
 $= (T^{17}) \bmod 3233$

The decryption function is: $\text{decrypt}(C) = (C^D) \bmod PQ$
 $= (C^{2753}) \bmod 3233$

To encrypt the plaintext value 123, do this:

$\text{encrypt}(123) = (123^{17}) \bmod 3233$
 $= 337587917446653715596592958817679803 \bmod 3233$
 $= 855$

To decrypt the cipher text value 855, do this:

$\text{decrypt}(855) = (855^{2753}) \bmod 3233$
 $= 123$



Recap

- Chiffrement (A)symétrique
 - Trouver un moyen de protéger le message a envoyer d'une lecture non autorisée ➔ *confidentialité*!
- Maintenant on va voir intégrité et authenticité (des messages)

Data Integrity

MAC (Message Authentication Code)

MAC (Message Authentication Code)

- Alice veut envoyer a Bob avec qui elle partage un secret
- Le message n'est pas secret...mais Alice ne veut pas qu'il soit modifié pendant le transit.
- Idée du MAC
 - Calcule un checksum et envoyer avec le message
 - Si le message est modifié, le checksum devient invalide
 - Le checksum doit être difficile à forger
 - Peut-être utiliser aussi pour vérifier que des documents stockés ont subi des modifications

MAC (Message Authentication Code)

- Si Alice et Bob partagent un secret comment
 - Trouver une fonction $F(M, K) = T$
 - Envoyer (M, T)
 - La fonction doit vérifier: $M \neq M' \rightarrow F(M, K) \neq F(M', K)$
 - Doit être robuste contre les attaques a textes clair connus
 - Eve observe $(M_1, T_1), (M_2, T_2), \dots, (M_q, T_q)$
 - Ne doit pas être en mesure de créer un nouveau message M et un T correspondant qui est aussi valide
- Comment construire de MAC?

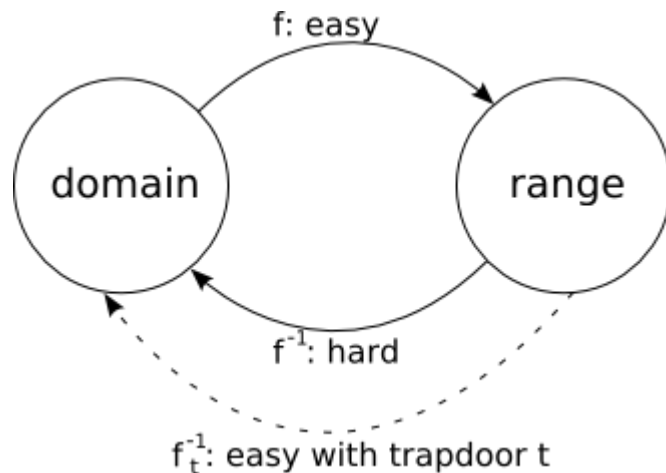
MAC (Message Authentication Code)

- **AES-EMAC**
 - Clef K constituée de 2 clef AES de 128 bits chacune
 - Message découpé en séquences de 128 bits: $P_1, P_2, P_3, \dots, P_n$
 - Initialisation: $S_0 = 0$
 - Répéter: $S_i = AES_{K_1}(S_{i-1} \oplus P_i), \quad i = 1, 2, 3, \dots, n$
 - Finalement: $T = AES_{K_2}(S_n)$

Solutions cryptographiques

Authentication des messages

- Fonction à sens unique: **fonction de hashage!**



Facile de calculer le hash (signature) a partir du message!

« Impossible » de forger un message avec le même hash!

Fonctions de Hashage cryptographiques

- Fonction déterministe et sans clef $H(M)$ (hash)
- Prend un message de taille arbitraire et produit un hash de taille fixe
- Peut-être utiliser pour créer une empreinte du message
- Caractéristiques
 - **Fonction à sens unique:** facile de calculer $H(M)$ mais difficile de trouver M à partir de $H(M)$
 - **Robuste contre les collisions:** difficile de trouver $M \neq M'$ de telle sorte que $H(M) = H(M')$

Fonctions de Hashage cryptographiques

- Exemples: **Message Digest (MD)**
 - MD5 la fonction hashage la plus utilisée pendant des années
 - La famille comprend aussi: MD2, MD4, MD5, MD6
 - A été adopte comme standard sur Internet
 - 128 bits
 - Utilisée par serveurs pour vérifier intégrité des fichiers
 - En 2004, une attaque (collision) a été trouvée, qui dure moins d'une heure sur une machine moderne.
 - MD5 n'est plus recommandée

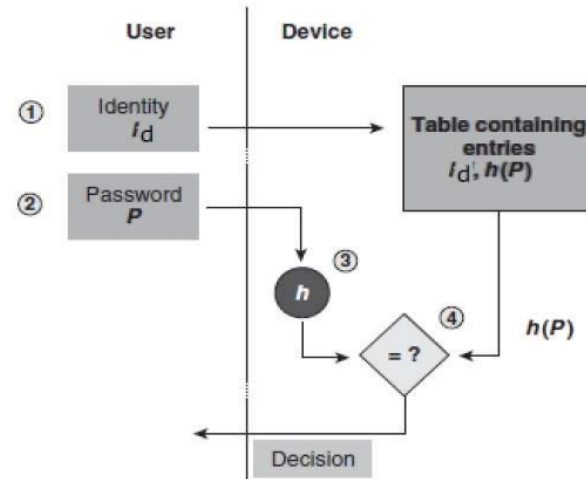
Fonctions de Hashage cryptographiques

- Exemples: **Secure Hash Function (SHA)**
 - Famille contient SHA-0, SHA-1, SHA-2, SHA-3
 - SHA-0: publiée en 1993 mais avec des failles découvertes en 1995
 - SHA-1:
 - développée en 1995 et très répandue.
 - Utilisée par bcps de protocoles comme SSL (Secure Socket Layer)
 - Vulnérabilité découverte en 2005
 - SHA-2:
 - Plus robuste avec plusieurs variantes
 - Pas d'attaques connues a nos jours
 - Améliorée en 2012 pour créer une nouvelle version
 - SHA-3: version utilisée today!

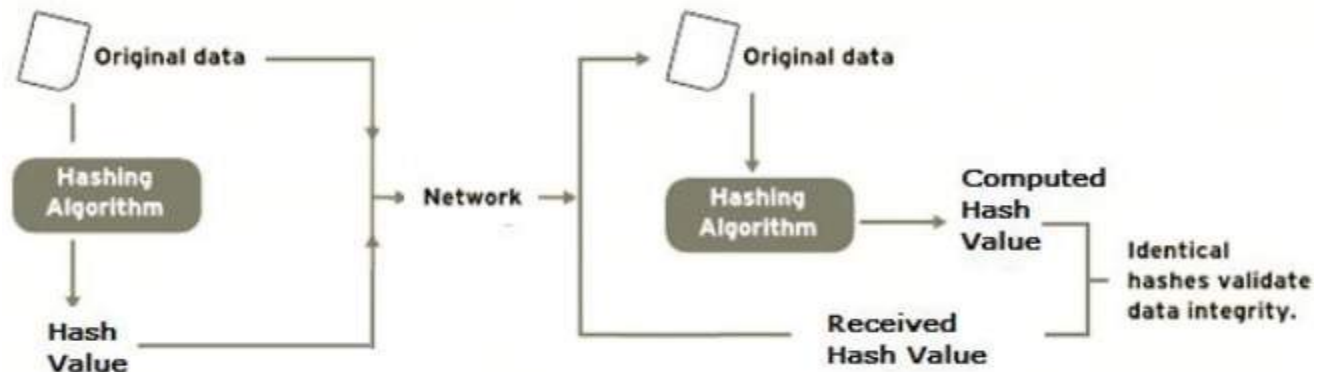
Fonctions de Hashage cryptographiques

- Applications:

- Storage des mots de passe



- Intégrité des données



Fonctions de Hashage cryptographiques



Document



Message Digest Function



Hash Value

Hash functions **calculate a unique fixed-size bit string** representation called a message digest of any arbitrary block of information



If any given bit of the function's input is changed, every output bit has a **50 percent** chance of changing



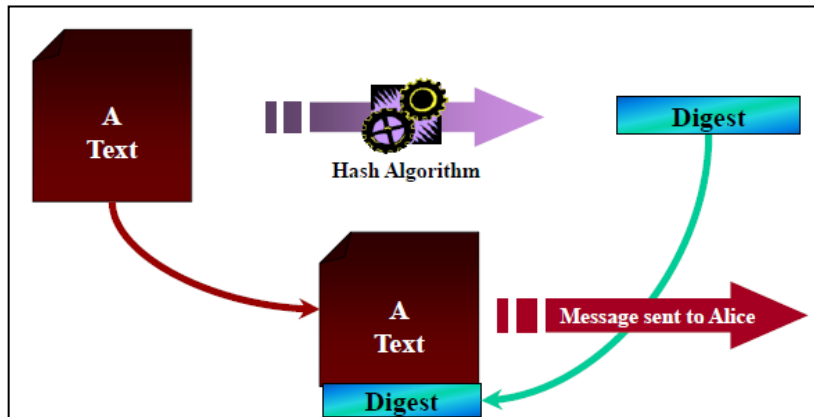
It is computationally infeasible to have two files with the **same message digest value**



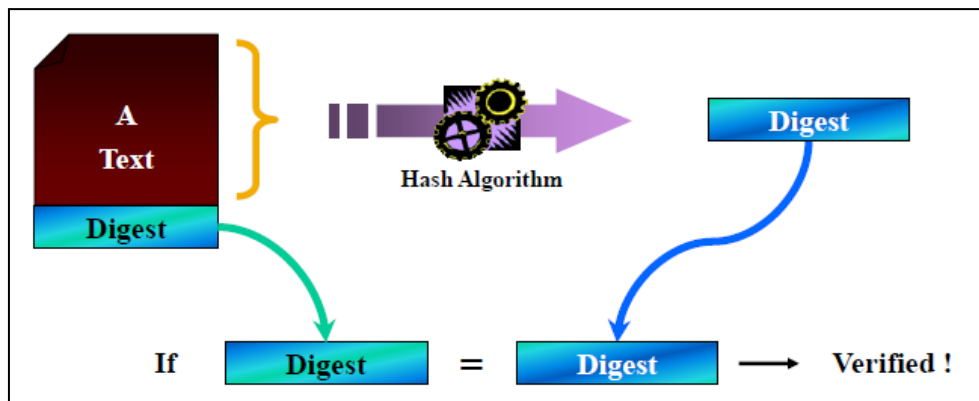
Note: Message digests are also called one-way hash functions because they cannot be reversed

Solutions cryptographiques

Authentification des messages (Intégrité)



Authentification:
Générer une signature
unique du message.



Vérification:
Re-calculer la signature
et comparer avec celle
reçue!

Fonctions de Hashage cryptographiques

MD5 Hash Calculator



<http://md5calculator.chromefans.org>

Hash Droid



<https://play.google.com>

Hash Calculator



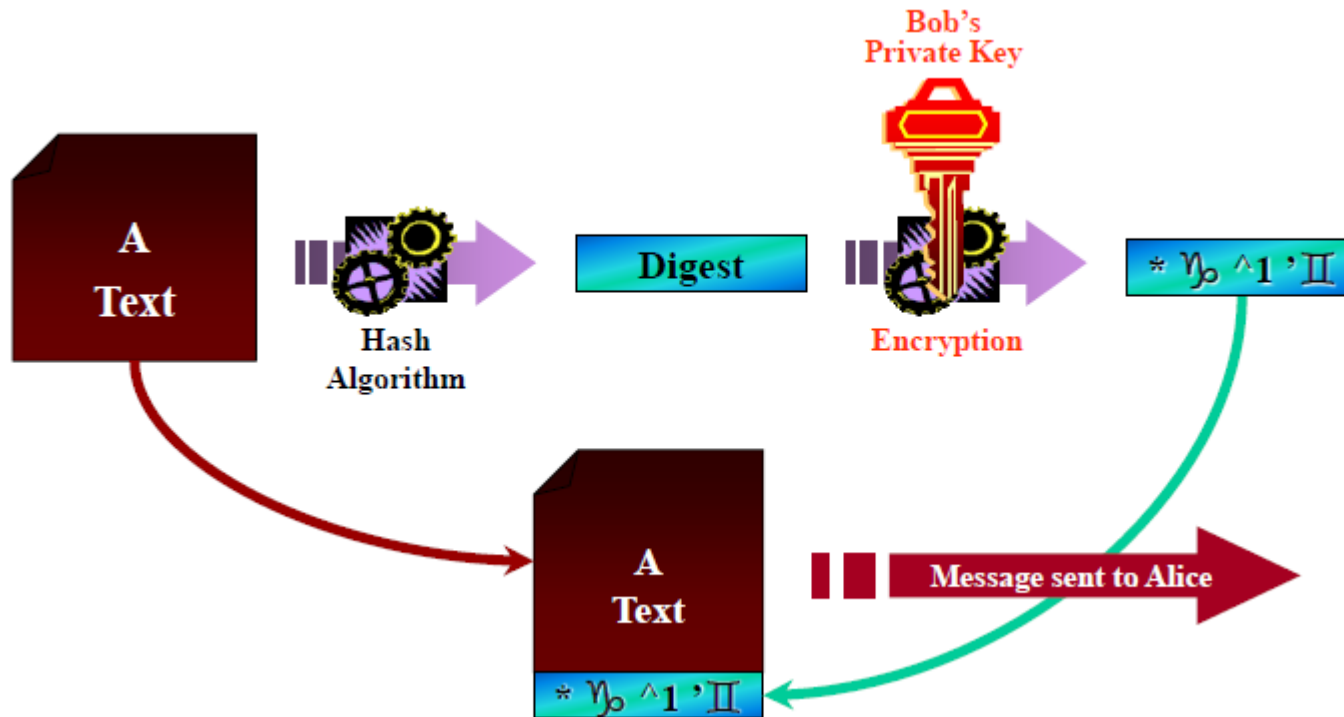
<https://play.google.com>

Signatures Digitales

- Version clef publique du MAC
 - Alice veut envoyer un message a Bob sur un canal non-securisée
 - Alice a une clef publique (clef de vérification) et une clef privée (clef de signature)
 - Bob doit connaitre la clef publique de Alice (qui garde jalousement sa clef privée)
 - Alice signe le message avec sa clef privée
 - Bob vérifie le message et la signature avec la clef publique de Alice
 - Si vérification est OK: message est **authentique**, envoyé par Alice.
- **Exemple:** RSA

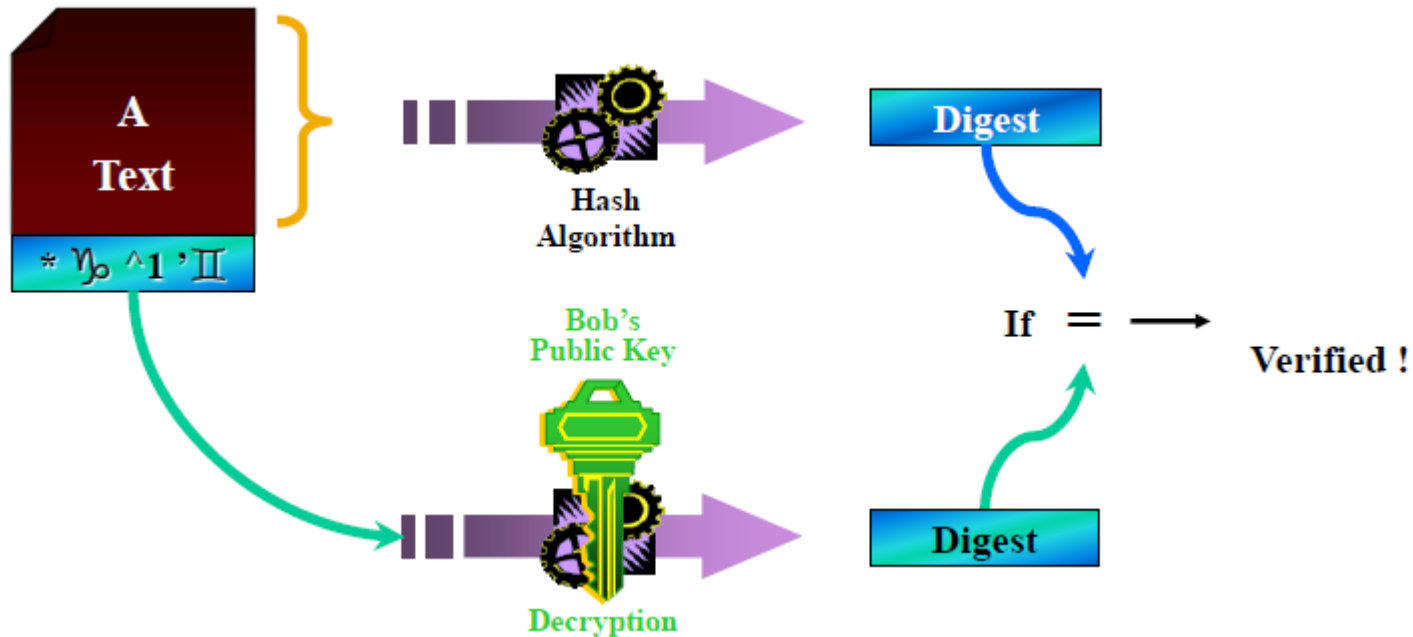
Solutions cryptographiques

Signature Digitale: Signature



Solutions cryptographiques

Signature Digitale Vérification!



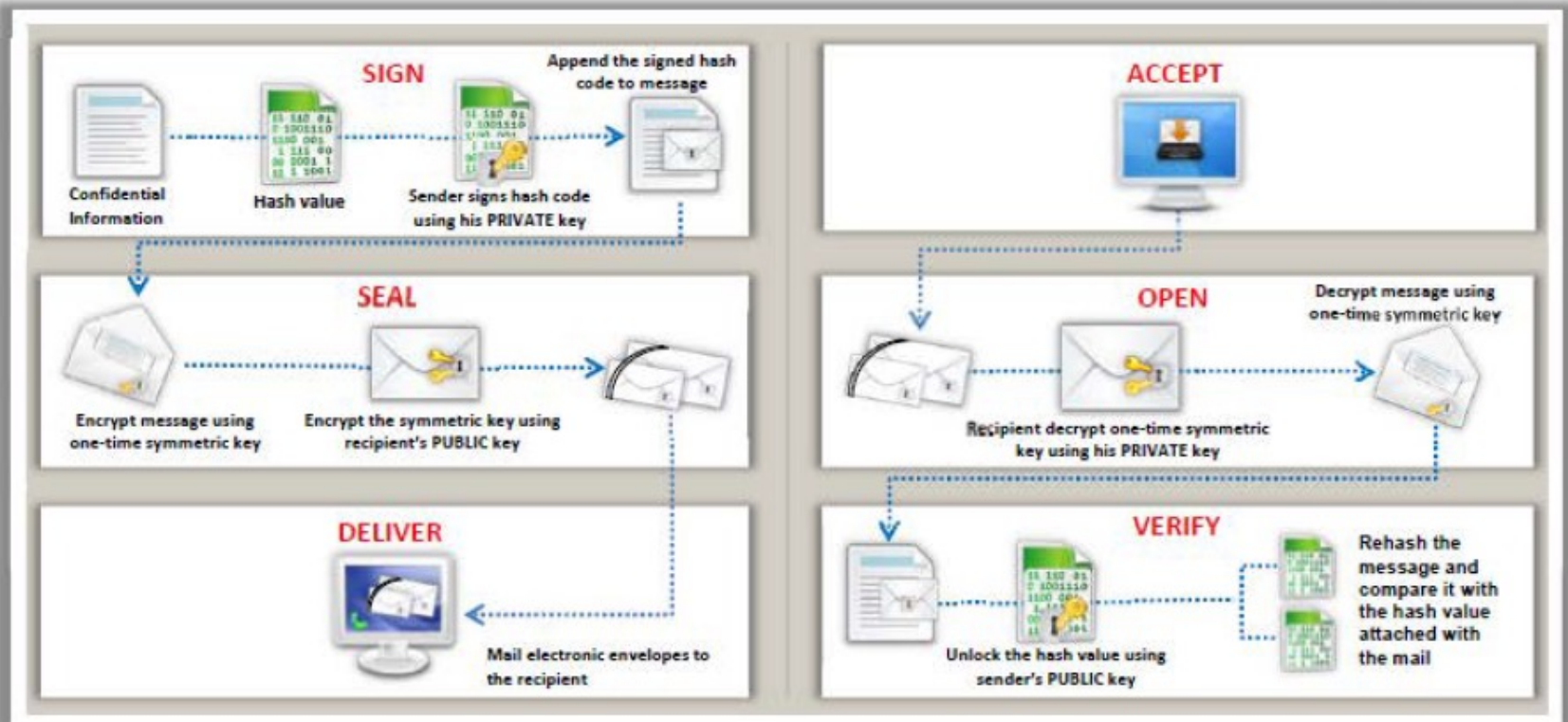
Signatures Digitales

1

Digital signature used asymmetric cryptography to simulate the security properties of a **signature in digital, rather than written form**

2

A digital signature may be further protected, by **encrypting the signed email** for confidentiality



Solutions cryptographiques

EXERCICE 1:

Astou veut envoyer un message M à Babacar.

Astou connaît la clef publique de Babacar, mais Babacar ne connaît rien de Astou.

Eva est un attaquant qui peut lire tous les messages qui passent dans le canal, alors que Mamadou est un attaquant qui peut modifier tout message qui passe dans le canal.

Q1 : Supposons que Astou utilise la clef publique de Babacar pour encrypter le message. Est-ce que le message est protégé contre

Q1.a : une attaque de la part de Eva?

Q1.b : une attaque de la part de Mamadou?

Normalement, pour s'assurer que le message est bien envoyé par Astou, Babacar peut vérifier un hash (MAC) que Astou envoie avec le message M .

Q2 : Pourquoi ceci n'est-il pas possible ?

Comme solution, Astou envoie sa clef publique en même temps que le message et le hash (MAC), le tout encrypté avec sa clef privée.

Q3 : Est-ce que le message est maintenant protégé contre

Q3.a : une attaque de la part de Eva?

Q3.b : une attaque de la part de Mamadou?

Solutions cryptographiques

EXERCICE 2:

Astou et Babacar ont une clef symétrique commune K .

Astou doit à Babacar 100'000CFA et cela fait longtemps elle n'a pas payé!

Ayant eu assez de demander, Babacar part à la police avec un message échangé précédemment avec Astou qui contient: « Je confirme que je te dois 100'000CFA » et signé avec la clef commune K .

À la police, Babacar clame qu'il a une preuve irréfutable car la cryptographie est parfaite.

A-t'il raison?

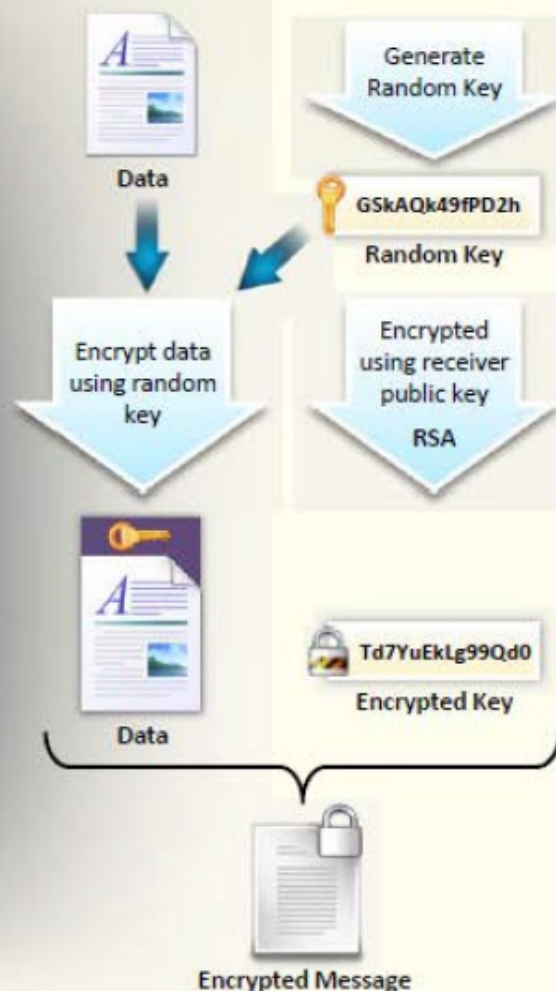
Secure Comm

Email Encryption

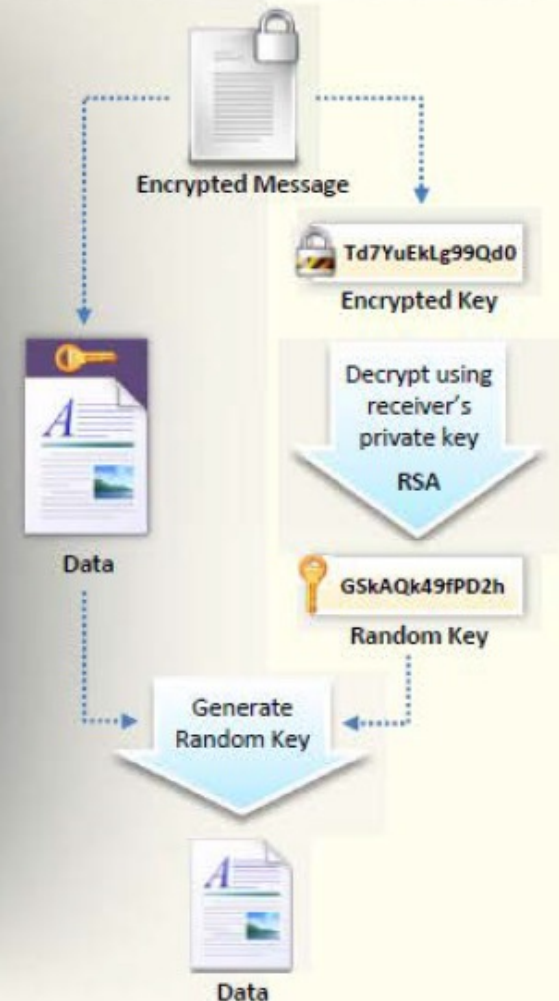
Pretty Good Privacy

- PGP (Pretty Good Privacy) is a protocol used to **encrypt** and **decrypt** data that provides **authentication** and **cryptographic privacy**
- PGP is often used for data **compression**, **digital signing**, encryption and decryption of **messages**, **emails**, **files**, **directories**, and to enhance privacy of email communications
- PGP combines the best features of both **conventional** and **public key cryptography** and is therefore known as **hybrid cryptosystem**

PGP Encryption

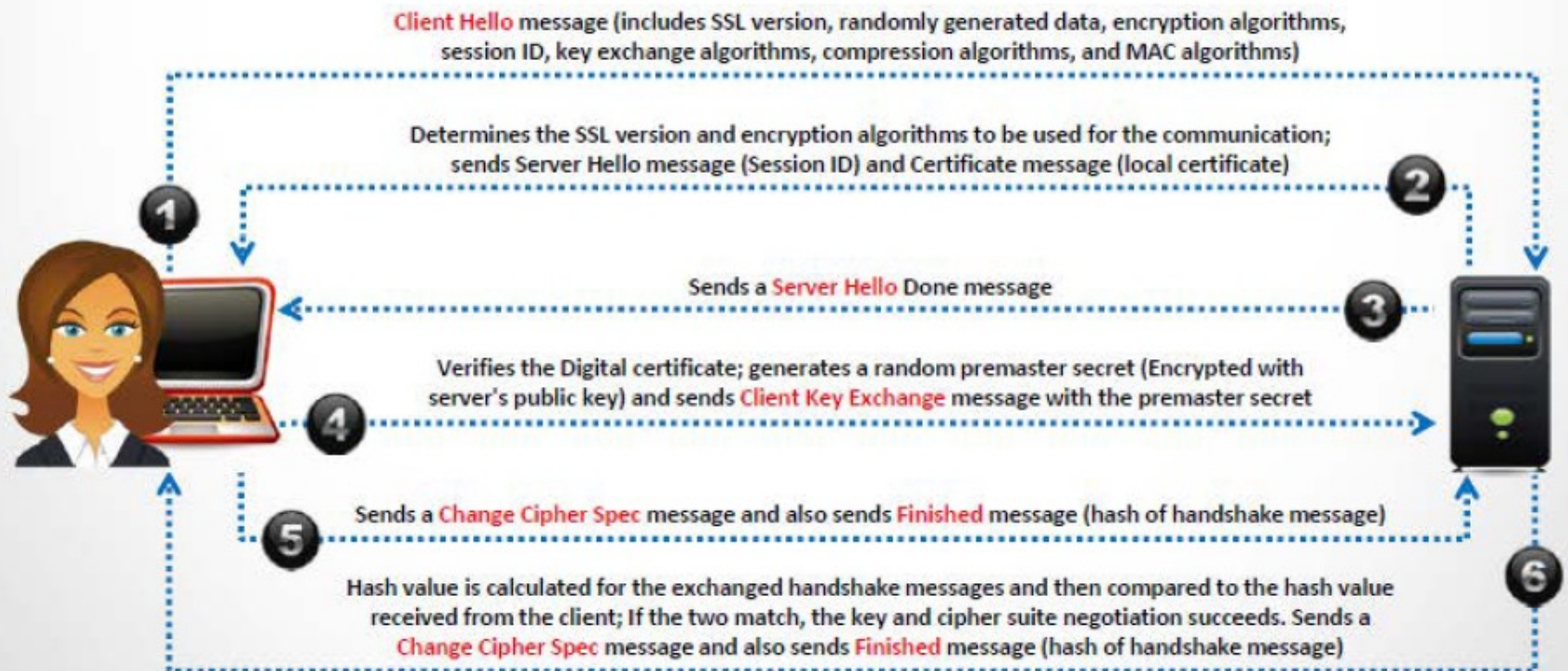


PGP Decryption



SSL (Secure Socket Layer)

- SSL is an application layer protocol developed by Netscape for **managing the security** of a message transmission on the Internet
- It uses **RSA asymmetric (public key) encryption** to encrypt data transferred over SSL connections



TSL

- TLS is a protocol **to establish a secure connection** between a client and a server and ensure privacy and integrity of information during transmission
- It uses the RSA algorithm with 1024 and 2048 bit strengths

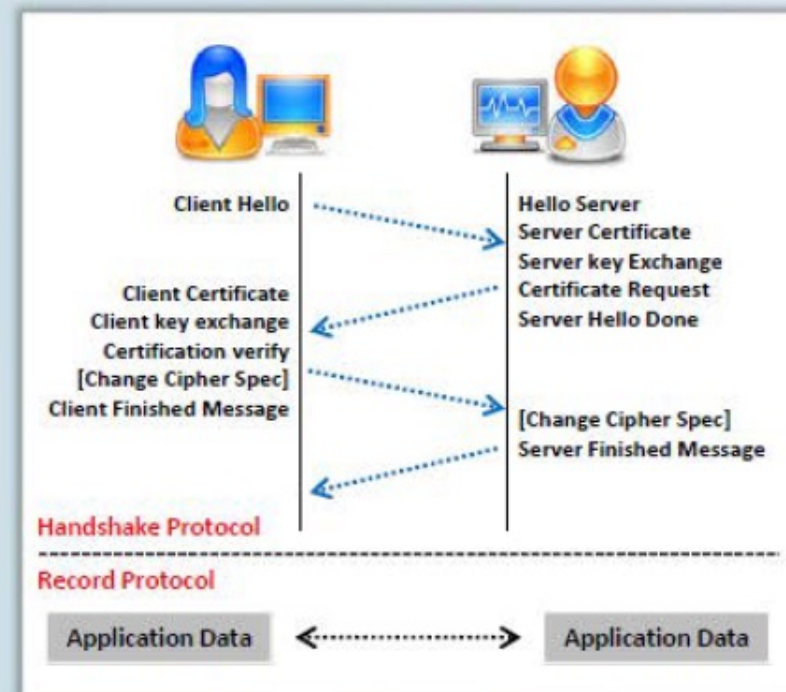


TLS Handshake Protocol

It allows the client and server to authenticate each other, select encryption algorithm, and exchange symmetric key prior to data exchange

TLS Record Protocol

It provides secured connections with an encryption method such as Data Encryption Standard (DES)



Problèmes avec Crypto a Clef Publique?

PKI

Public Key Infrastructure (PKI) is a **set of hardware, software, people, policies, and procedures** required to create, manage, distribute, use, store, and revoke **digital certificates**

Components of PKI

1

Certificate Management System

Generates, distributes, stores, and verifies certificates

2

Digital Certificates

Establishes credentials of a person when doing online transactions

3

Validation Authority (VA)

Stores certificates (with their public keys)

4

Certificate Authority (CA)

Issues and verifies digital certificates

5

End User

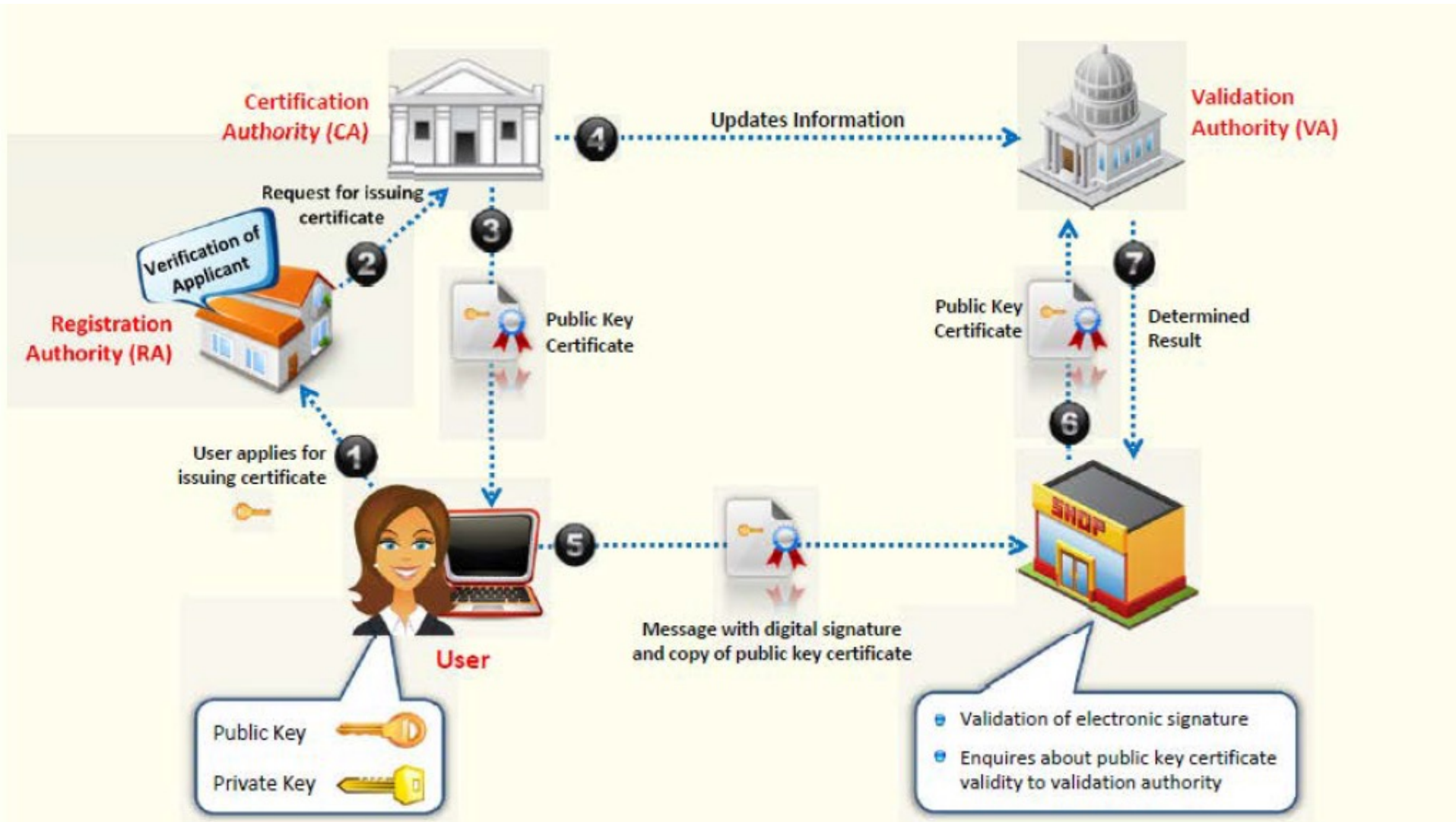
Requests, manages, and uses certificates

6

Registration Authority (RA)

Acts as the verifier for the certificate authority

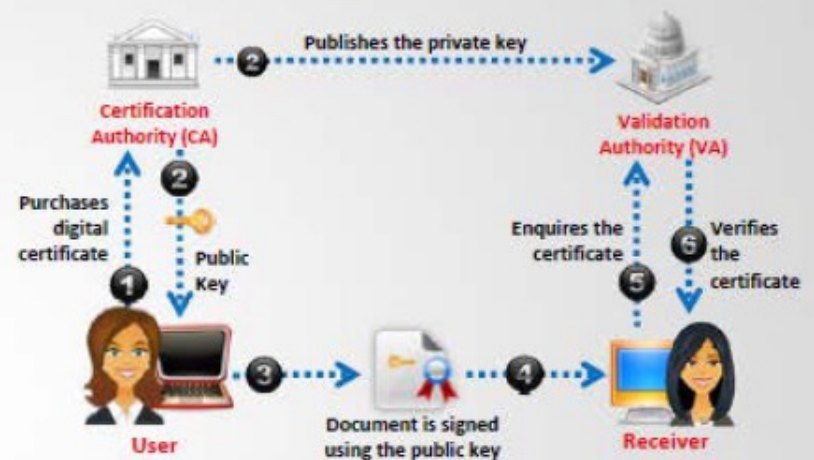
PKI



PKI

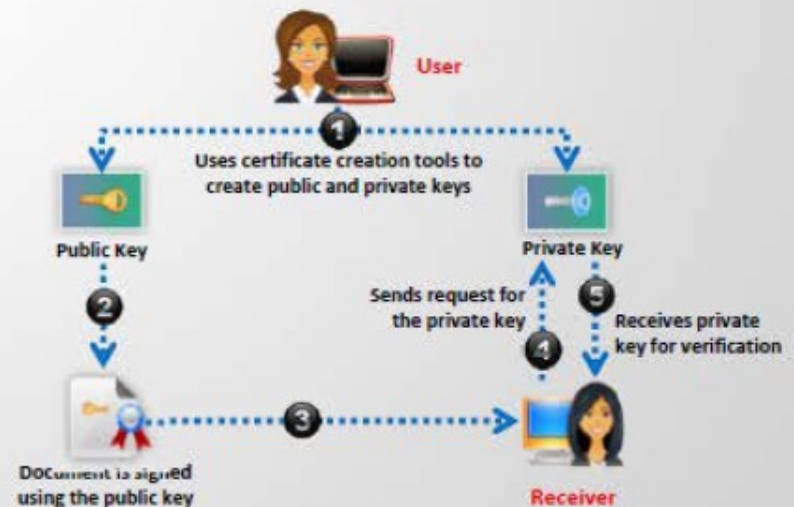
Signed Certificate

- User approaches a trustworthy **Certification Authority (CA)** and purchases digital certificate
- User gets the **public key** from the CA, he signs the document using it
- The signed document is delivered to the receiver
- The receiver can verify the certificate by enquiring in **Validation Authority (VA)**
- VA verifies the certificate to the receiver but it does not **share private key**



Self-signed Certificate

- User creates public and private keys using a tool such as **Adobe Reader, Java's keytool, Apple's Keychain**, etc.
- User uses public key to **sign the document**
- The **self-signed document** is delivered to the receiver
- The receiver request the user for his **private key**
- User **shares the private key** with the receiver



Garantie de Sécurité (Brute Force)



Attack Scheme

Defeating a cryptographic scheme by **trying a large number of possible keys** until the correct encryption key is discovered



Brute-Force Attack

Brute-force attack is a **high resource and time intensive process**, however, more certain to achieve results



Success Factors

Success of brute force attack depends on **length of the key, time constraint**, and **system security mechanisms**

Power/Cost	40 bits (5 char)	56 bit (7 char)	64 bit (8 char)	128 bit (16 char)
\$ 2K (1 PC. Can be achieved by an individual)	1.4 min	73 days	50 years	10^{20} years
\$ 100K (this can be achieved by a company)	2 sec	35 hours	1 year	10^{19} years
\$ 1M (Achieved by a huge organization or a state)	0.2 sec	3.5 hours	37 days	10^{18} years

Estimate Time for Successful Brute-force Attack

Questions?